CareFusion AI
Full QA Test Plan

Target: https://carefusion-roan.vercel.app (production alpha demo)

For: external senior tester (all roles, all states, account creation, authentication)

Date: 31 October 2026 **Version:** 1.0

Contents: Start here · Part A (access, sign-in, registration, accounts, citizen app) · Part B (doctor, nurse, lab, radiology, pharmacist, end-to-end chains) · Part C (admin consoles, government console, notification matrix, access control, safety, security, known issues)

SYNTHETIC DEMO DATA. Never enter real personal data.

Start here: how to test CareFusion AI on the live site

1. What you are testing

- **Site:** https://carefusion-roan.vercel.app (production, deployed on Vercel; database on Neon; files on Cloudflare R2).
- **What it is:** an alpha demo of a medical-affairs platform for government health services. **All data is synthetic.** Never type real names, phone numbers, Aadhaar numbers or any real personal data.
- **Your job:** test every role, every page, every state and every notification. Report anything that differs from "Expected result".

2. Things that are different from a normal product (read this first)

#	Fact	What it means for you
1	**Access-code gate.** The whole site asks for a shared code first.	Ask Athun for the code. 5 wrong codes from one IP in 10 minutes gives a 429 lockout. The cookie lasts 12 hours.
2	**There is no real login.**	Open `/demo-signin` and pick one of 12 fixed demo people. Passwords, OTP login, MFA, password reset and staff activation are not built yet. Do not report "no password field" as a bug; it is a known gap.
3	**Newly registered accounts cannot sign in.**	Registration writes real rows (status `pending` or `active`) but the screen then signs you in as the seeded demo person. You verify a new account through its result screen and through the approval inbox of the admin who must approve it.
4	**Production data is shared and permanent.**	Other testers use the same database. Records you create cannot be deleted (documents, audit log, events, ratings are immutable by design). Prefix every name or note you type with `QA-` so it can be found later. Restore anything you change (flags, stock, bed status) as each test says.
5	**The server clock is frozen** at 17 Oct 2026, 14:45 IST (`DEMO_NOW`).	"Today", slot times, expiry dates and 7-day deadlines are all measured against that date, not the real date. The web page clock ticks forward after load, so small differences are expected (listed in Known Issues).
6	**Government services are mock.**	Aadhaar e-KYC, face check, ABHA, HPR, HFR, drug licence and e-Sign are simulated. Demo OTP is always `123456`.
7	**AI is simulated** and always labelled "simulated AI output".	Do not judge medical accuracy. Judge labels, statuses, the review step and who can see the result.
8	**No real SMS, email or push.**	"Notification" means an in-app event: it appears as a toast (4 seconds) and in the bell/feed, polled every 3 seconds. Texts such as "told by SMS and email (mock)" are display text only.
9	**You have no database access.**	Everything is tested from the browser. For checks that need data you cannot see, the row says "ask Athun". For direct API checks use the browser Network tab, or `curl` (section 6).

3. The 12 demo people (sign in at `/demo-signin`)

Role	Name	Notes
CITIZEN	Anjali Menon	35, ABHA `DEMO-0000-1234`, main test patient. Family: Ravi Menon, Sarala Nair, Johnson Kuruvilla. Minors in the data (Diya Menon, Rahul Sasi) have no login.
DOCTOR	Dr. Arun Nair	General medicine, Demo General Hospital, HPR `DEMO-HPR-71-0042`. Anjali's treating doctor. Her booking: Wed 21 Oct 10:30, token 16.
NURSE	Lekha Pillai	Ward 3. Inpatient Thomas Kurian, Bed 7, NEWS 7.

Role	Name	Notes
LAB_TECH	Rahul Varghese	
RADIOLOGY_TECH	Fathima Beevi	
PHARMACIST	Joseph Mathew	Counter 2.
PHARMACY_ADMIN	Suma Thomas	Hospital pharmacy, licence `DEMO-DL-KL-2041`.
HOSPITAL_ADMIN	Dr. Meera Krishnan	Medical Superintendent, Demo General Hospital `DEMO-HFR-KL-0193`.
DISTRICT_ADMIN	Ajay Kumar	Pathanamthitta.
STATE_ADMIN	Latha Nair	Kerala.
ZONAL_ADMIN	R. Venkatesh	South zone.
CENTRAL_ADMIN	S. Banerjee	National.

Each role always signs in as the same person. To watch a notification travel from one role to another, open **a second browser tab** for the second role: the demo session lives in `sessionStorage`, so every tab can be a different role.

4. Mock data cheat sheet

Item	Value
Aadhaar number (mock)	any exactly 12 digits. Same number always gives the same person, so a second registration with it gives 409 "This Aadhaar identity is already registered". The number itself is never stored.
Aadhaar OTP	`123456` (pre-filled). Anything else gives `OTP_MISMATCH` "Invalid OTP".
Face check	passes by default. Force a fail with a selfie that is empty or the text `FAIL` (tester to confirm how the UI lets you do this).
Doctor HPR id	`DEMO-HPR-71-NNNN` (4 digits). Anything else: "HPR ID not found in registry".
Hospital HFR id	must start `DEMO-HFR-`. Pharmacy licence must start `DEMO-DL-`.
ABHA	`DEMO-0000-NNNN`. Created in the background after registration.
e-Sign	works only for doctors whose HPR id starts `DEMO-HPR-`.
Doctor key (rotating)	6 digits, changes every 10 seconds, single use. QR carries `cfkey:v1:<handle>:<code>`.

5. Suggested order of testing

1. Access gate and sign-in (AUTH).
2. Registrations and account states (REG, ACCT, ADM).
3. One role at a time: Citizen, Doctor, Nurse, Lab, Radiology, Pharmacist, Pharmacy admin, Hospital admin, District/State/Zonal/Central.
4. The multi-role end-to-end chains (E2E). Use several tabs.
5. The notification matrix (NOTIF), access control (RBAC), safety (SAFE), security and non-functional (SEC).
6. Known issues list: confirm each one and record expected vs actual.

6. Calling the API from your side (optional, for negative and access-control tests)

1. Enter the access code in the browser. In the developer tools, Network tab, copy the `cf_access` cookie value.
2. `curl -H 'Cookie: cf_access=<value>' -H 'Authorization: Bearer demo:<ROLE>' https://carefusion-roan.vercel.app/api/v1/<path>` where `<ROLE>` is one of the 12 role names, for example `PHARMACY_ADMIN`.
3. `X-Demo-Role: <ROLE>` also works. If both are sent the `Bearer demo:` value wins.
4. Errors look like `{ "success": false, "errorMessage": "..." }`. Status codes: 400 bad input, 401 not signed in / no access cookie, 403 not allowed, 404 not found, 409 conflict with current state, 429 too many tries.

7. How to read the test tables

Every table has the same five columns:

Column	Meaning
ID	unique case number, use it in bug reports
Scenario	what is being tested
Steps	exact actions, in order
Expected result	what should happen, with exact message text where the code defines it
Who is notified	the exact accounts that receive an in-app event, and the event type. "No one" means no event at all. "No one (audit entry only)" means the action is written to the audit log but nobody gets an alert.

"Tester to confirm" means the code did not settle the answer: record what you see.

8. Severity and bug report

Severity	Meaning
S1 Blocker	data leak across people or roles, safety rule broken (see SAFE), site down, cannot continue
S2 Major	a feature gives wrong result or wrong people are notified
S3 Minor	wrong text, layout, small inconsistency
S4 Cosmetic	spelling, spacing

Bug report template: **ID** · **Title** · **Role + tab** · **Steps** · **Expected** · **Actual** · **Severity** · **Screenshot / Network response** · **Time (IST) and browser**.

9. Safety rules that must never break (report any as S1)

1. The "SYNTHETIC DEMO DATA" banner is on every screen.
2. No raw Aadhaar number appears anywhere (screens, network responses).
3. Every AI output is labelled as simulated and is never presented as a diagnosis.

4. A citizen sees an AI result only after a doctor has reviewed it (and not if the doctor rejected it).
5. Patient events never reach district, state, zonal or central admins.
6. A doctor cannot open their own citizen record.
7. Emergency alerts cannot be switched off by a citizen.
8. No real government logos or look-alike official login pages.

Part A: access, sign-in, registration, accounts and the Citizen app

AUTH: access gate and sign-in

Pages: every page; `/demo-signin`, `/login`, `/login/staff`, `/login/admin`, `/recovery`, `/staff/activate`. API: `/api/v1/access/*`, `/api/v1/auth/demo-login`, `/api/v1/auth/me`.

ID	Scenario	Steps	Expected result	Who is notified
AUTH-001	Gate shows first	1. Open the site in a fresh private window.	Access-code screen appears before any app page.	No one
AUTH-002	Correct code	1. Enter the correct code.	Granted; cookie `cf_access` set (HttpOnly, 12 h, Secure on https); landing page opens.	No one
AUTH-003	Wrong code	1. Enter a wrong code.	401 "That code is not right." Counter goes up.	No one
AUTH-004	Lockout	1. Enter 5 wrong codes in a row. 2. Enter a 6th wrong code.	429 "Too many wrong codes. Try again in a few minutes." Even the right code is refused until the 10-minute window passes (tester to confirm).	No one
AUTH-005	Correct code clears counter	1. Enter 3 wrong codes. 2. Enter the right code. 3. Sign out of the gate (clear cookie), enter 4 more wrong codes.	Right code clears the count, so 4 wrong codes after it do not lock you.	No one
AUTH-006	Cookie expiry	1. Delete the `cf_access` cookie. 2. Reload.	Gate shows again.	No one
AUTH-007	API without cookie	1. `curl https://carefusion-roan.vercel.app/api/v1/auth/me` with no cookie.	401 `{accessRequired:true}`.	No one
AUTH-008	Open endpoints	1. Call `/health`, `/api/v1/clock`, `/api/v1/access/status` with no cookie.	200. Clock returns `frozen:true` and 2026-10-17T09:15:00Z. `status` returns `required:true,granted:false`.	No one
AUTH-009	Demo sign-in, every role	1. Open `/demo-signin`. 2. Sign in as each of the 12 roles in turn.	Each lands on its own home (`/citizen`, `/doctor`, `/nurse`, `/lab-tech`, `/radiology-tech`, `/pharmacist`, `/pharmacy-admin`, `/hospital-admin`, `/district-admin`, `/state-admin`, `/zonal-admin`, `/central-admin`). Name matches section 3 of the Start-here page.	No one (audit entry `auth.demo_login`)
AUTH-010	Citizen login page	1. Open `/login`. Toggle user/doctor. 2. Click "Verify and continue" and the demo link.	Signs in as demo citizen / demo doctor. Real fields (password, OTP) are visual only.	No one (audit only)
AUTH-011	Staff and admin login pages	1. Open `/login/staff` and `/login/admin`. 2. Use each demo link.	Staff roles and admin roles sign in. Jan Parichay / hardware key buttons are UI only. No real government logo is shown.	No one (audit only)
AUTH-012	Logout	1. Sign in as Citizen. 2. Log out. 3. Press browser Back.	Returns to `/login`. Back does not show protected data (data call gives 401).	No one

ID	Scenario	Steps	Expected result	Who is notified
AUTH-013	Session lives in the tab	1. Sign in as Doctor in tab 1. 2. Open a new tab to the same site.	New tab is signed out (sessionStorage is per tab). Closing the tab ends the session.	No one
AUTH-014	Signed-out redirect	1. Signed out, open `/doctor`, `/citizen/vitals`, `/hospital-admin`.	Redirects to `/login`.	No one
AUTH-015	Wrong role page	1. Sign in as Citizen. 2. Type `/doctor` in the address bar. 3. Repeat for `/pharmacist`, `/central-admin`.	Access-denied screen (client side). Also test the API: `curl .../api/v1/doctor/home` as `demo:CITIZEN` gives 403.	No one
AUTH-016	Unknown route	1. Open `/nonsense`.	404 screen with the demo banner.	No one
AUTH-017	Invalid role	1. `POST /api/v1/auth/demo-login` with `{"role":"KING"}`.	401 "Invalid role".	No one
AUTH-018	Tampered token	1. Send `Authorization: Bearer demo:ADMINX` or a random string.	401.	No one
AUTH-019	Header tampering	1. As Citizen tab, edit request: add `X-Demo-Role: CENTRAL_ADMIN`.	Known gap: demo mode accepts it (any role can be chosen). Record that it works and that the role guard then behaves as CENTRAL_ADMIN.	No one
AUTH-020	`auth/me`	1. Sign in as each role. 2. Call `/api/v1/auth/me`.	Returns the matching person and role.	No one
AUTH-021	Recovery page	1. Open `/recovery`. 2. Try forgot-password and lost-phone paths.	Screens open and show the demo banner. Nothing real is sent (not built).	No one
AUTH-022	Staff activation page	1. Open `/staff/activate`.	Page opens; submitting only signs in as the demo nurse (known gap).	No one
AUTH-023	`/screens` gallery	1. Signed out, open `/screens` and `/screens/<slug>`.	Design gallery opens without sign-in (open question: intended?). Data calls on those pages return 401.	No one
AUTH-024	Banner on auth pages	1. Check the SYNTHETIC DEMO DATA banner on landing, login, register, recovery, 404, access-denied, splash.	Banner on every one.	No one

REG-CITIZEN: citizen registration (`/register`)

Steps in the UI: consent, details, e-KYC with OTP, face check, ABHA, submit, result. API `POST /api/v1/register/citizen` plus the mock connector calls.

ID	Scenario	Steps	Expected result	Who is notified
REG-001	Happy path adult	1. Open `/register`. 2. Accept the privacy notice. 3. Fill details (name prefix `QA-`). 4. Enter a new 12-digit Aadhaar, send OTP, keep `123456`. 5. Run face check. 6. Submit.	Result screen shows a `personId` UUID with a copy button. Account is `active` straight away.	No one (audit entry `registration.citizen`)
REG-002	Consents stored	1. After REG-001 tick/untick location logging and AI research on the consent step (repeat with a new Aadhaar).	Consents `privacy_notice` (demo-v1), `location_logging`, `ai_research` follow your choices (verify via a later profile/settings view or ask Athun).	No one
REG-003	Consent required	1. Try to continue without accepting the privacy notice.	Cannot continue.	No one
REG-004	Aadhaar not 12 digits	1. Enter 11 digits, then 13 digits, then letters.	"Aadhaar number must be 12 digits".	No one
REG-005	Wrong OTP	1. Enter OTP `000000`.	`OTP_MISMATCH` "Invalid OTP".	No one
REG-006	Missing or reused transaction	1. Call verify with no `txnId`. 2. Reuse an old txn after changing the Aadhaar.	`INVALID_TXN`.	No one
REG-007	Same identity data	1. Register twice with the same Aadhaar number.	Second try 409 "This Aadhaar identity is already registered".	No one
REG-008	Duplicate phone	1. Register with a new Aadhaar but a phone already used.	409.	No one
REG-009	Duplicate email	1. Same with a used email.	409.	No one
REG-010	Face check fail	1. Run the face check with the failing selfie (see cheat sheet).	match=false, confidence 12.3; step 3 stays blocked. Cannot submit (`faceCheckPassed` must be true).	No one
REG-011	Face check no token	1. Call face check with no token.	`INVALID_TOKEN`.	No one
REG-012	Raw Aadhaar rejected	1. Call `POST /register/citizen` with `aadhaarToken` set to a plain 12-digit number.	400. Nowhere in any response is a raw Aadhaar shown.	No one
REG-013	Password rule	1. Enter a password shorter than 12 characters (if the form asks).	Rejected by validation. (No password is stored; tester to confirm field exists.)	No one
REG-014	Minor with guardian	1. Enter a date of birth under 18. 2. Enter the guardian's `personId` of an active citizen (use the Anjali `personId`; copy it from a registration result of your own). 3. Submit.	Allowed. `handover_due_on` = DOB + 18 years. Consent `minor_guardian` stored.	Guardian sees the minor's events in their feed
REG-015	Minor without guardian	1. Under-18 DOB, no guardian.	Rejected (guardian required).	No one
REG-016	Guardian not active/not a citizen	1. Minor with a random UUID as guardian. 2. Guardian who has only a pending account.	Rejected.	No one

ID	Scenario	Steps	Expected result	Who is notified
REG-017	Adult with guardian	1. Adult DOB with a guardian id.	Rejected.	No one
REG-018	Boundary age	1. DOB exactly 18 years ago today (frozen date 17 Oct 2026), and one day after.	Exactly 18 is an adult; one day younger is a minor.	No one
REG-019	ABHA background creation	1. After REG-001 wait, then open the new profile data (ask Athun, or check the result screen).	ABHA `DEMO-XXXX-XXXX` with `name.suffix@abdm` appears later. The submit response itself has no ABHA.	No one
REG-020	Free-text safety	1. Put `<script>alert(1)</script>` and a 300-character name in details.	Escaped or rejected, no script runs.	No one
REG-021	Navigate back	1. Go back a step and change the details, then forward.	Entered values kept or cleanly reset; no double registration.	No one
REG-022	Double submit	1. Click Submit twice quickly.	One account only; second gives 409 or is ignored.	No one

REG-DOCTOR, REG-HOSPITAL-ADMIN, REG-PHARMACY-ADMIN

Pages `/register/doctor`, `/register/hospital-admin`, `/register/pharmacy-admin`. Each needs the `personId` of an existing active citizen (copy it from REG-001's result screen). Each creates a `pending` user and an approval request for the district admin, due in 7 days.

ID	Scenario	Steps	Expected result	Who is notified
REG-030	Doctor, happy path	1. Complete REG-001 and copy the `personId`. 2. Open `/register/doctor`, paste it. 3. HPR `DEMO-HPR-71-0100`, verify. 4. Pick a hospital and employment type. 5. Submit.	Pending doctor account, doctor profile, approval request (subject `doctor`, level district, due in 7 days, `hpr_verified:true`). UI then signs you in as demo doctor (known behaviour).	No event. District admin sees the request in the approval inbox (check as Ajay Kumar). Audit `registration.doctor`.
REG-031	HPR invalid	1. HPR `ABC-123`, then `DEMO-HPR-71-12`.	"HPR ID not found in registry". Server also re-verifies on submit.	No one
REG-032	Missing/unknown personId	1. Leave empty; paste a random UUID.	Rejected (400/404).	No one
REG-033	Duplicate doctor account	1. Register the same `personId` as doctor again.	409.	No one
REG-034	Who sees it	1. Sign in as DISTRICT_ADMIN (Ajay), open Approvals. 2. Then as HOSPITAL_ADMIN (Meera).	Doctor request is in the district inbox, not in the hospital admin's Approvals (as coded; open question whether that is intended).	No one

ID	Scenario	Steps	Expected result	Who is notified
REG-040	Hospital admin, happy path	1. Use a new `personId`. 2. Open `/register/hospital-admin`, pick an active hospital, HFR starts `DEMO-HFR-`. 3. Submit.	Pending account plus approval to district. UI then signs in as demo hospital admin.	District admin inbox only. Audit `registration.hospital_admin`.
REG-041	HFR invalid / hospital inactive	1. HFR `XYZ-1`. 2. Pick an inactive hospital (if listed).	Rejected.	No one
REG-050	Pharmacy admin, happy path	1. New `personId`. 2. Open `/register/pharmacy-admin`, pick a pharmacy, licence `DEMO-DL-KL-9999`. 3. Submit.	Pending account plus district approval. UI signs in as demo pharmacy admin.	District admin inbox only. Audit `registration.pharmacy_admin`.
REG-051	Licence invalid	1. Licence `LIC-1`.	Rejected.	No one
REG-052	Lists	1. Open the district, hospital and pharmacy drop-downs.	Kerala districts; active hospitals; pharmacies. No duplicates.	No one
REG-053	New account cannot log in	1. After REG-030/040/050 try to sign in as that new person on `/login` or `/demo-signin`.	There is no way to; sign-in only offers the 12 seeded people (known gap; record it).	No one
REG-054	Required fields / XSS	1. Submit each form empty. 2. Put markup in free text.	Field-level errors; markup escaped.	No one

ACCT: account states and transitions

States: `pending`, `active`, `rejected`, `suspended`, `deactivated`, `locked_deceased`. You see them through the approval inbox, pharmacist/staff lists and result screens.

ID	Scenario	Steps	Expected result	Who is notified
ACCT-001	pending to active	1. Register a doctor (REG-030). 2. As Ajay Kumar (District), open Approvals, open the request, Approve.	Request `approved`; account `active`. Audit `approval.approved`.	No event; audit only
ACCT-002	pending to rejected	1. Same request, choose Reject with no reason. 2. Reject with a reason.	1: refused, reason needed. 2: `rejected`, reason saved. Audit `approval.rejected`.	No event; audit only
ACCT-003	More info	1. Choose "more info" with a note. 2. Approve the same request later.	Status `more_info`; approving resumes it. Audit `approval.more_info`.	No event; audit only
ACCT-004	Escalate	1. Escalate the request. 2. Look in the district inbox and the state admin inbox.	Original hidden from district, live copy appears one level up (state). Audit `approval.escalated`.	No event; audit only

ID	Scenario	Steps	Expected result	Who is notified
ACCT-005	Pharmacist deactivate/reactivate	1. As Suma Thomas (Pharmacy admin) deactivate an `active` pharmacist. 2. Reactivate it. 3. Try to deactivate an already deactivated one (Bindu Varghese).	Only `active` can be deactivated; only `deactivated` can be reactivated; others refused.	No one (audit)
ACCT-006	Staff created active	1. As Dr. Meera Krishnan create a nurse (`QA-` name). 2. As Suma Thomas create a pharmacist.	Created `active` immediately (no activation link). Cannot sign in as them.	No one
ACCT-007	Doctor has two accounts	1. Sign in as Dr. Arun Nair. Open a patient, then try to open Dr. Nair's own record (his citizen identity).	Refused: a doctor cannot open their own citizen record (API 403).	No one
ACCT-008	Locked deceased	1. Not testable from the UI. Ask Athun whether a seeded death record exists.	A death record locks every account of the person.	No one
ACCT-009	Suspension	1. Look for any suspend control in the admin screens.	None expected (only metadata exists; record whether you find one).	No one
ACCT-010	Face-flagged citizen	1. Look for a "flagged citizen" approval.	Designed but not coded: citizens are always auto-activated.	No one

ADM: admin and staff creation

ID	Scenario	Steps	Expected result	Who is notified
ADM-001	Central creates zonal	1. As S. Banerjee, create a zonal admin (zone required, name `QA-`).	Pending user, admin post row, approval request (rule zonal_admin: central; needs two persons).	No event; central inbox
ADM-002	Zonal creates state	1. As R. Venkatesh create a state admin (state required).	Pending; approval to central.	No event
ADM-003	State creates district	1. As Latha Nair create a district admin (district required).	Pending; approval to zonal.	No event
ADM-004	Wrong creator	1. As District admin call create-admin. 2. As Central create a district admin directly.	403 for the wrong creator role.	No one
ADM-005	Missing area	1. Create each admin type without zone/state/district.	400 validation.	No one
ADM-006	Create staff	1. As Dr. Meera Krishnan create nurse, lab and radiology staff with valid hospital and department; then with invalid hospital/department.	Valid: created `active`. Invalid: 400.	No one
ADM-007	Create pharmacist	1. As Suma Thomas create a pharmacist with pharmacy + registration number; then without.	Valid: active. Missing: 400.	No one
ADM-008	Invites	1. As Suma create an invite. 2. Resend. 3. Revoke. 4. Create a second open invite for the same person.	Expires in 7 days; second open invite for the same person refused; no accept endpoint (known gap).	No one

CITIZEN: Citizen app (sign in as Anjali Menon)

Routes: `/citizen`, `/citizen/home`, `/citizen/access`, `/citizen/documents`, `/citizen/dates`, `/citizen/vitals`, `/citizen/ai-chat`, `/citizen/messages`, `/citizen/care`, `/citizen/medicines`, `/citizen/blood`, `/citizen/organ`, `/citizen/reviews`, `/citizen/complaints`, `/citizen/profile`, `/citizen/alerts`, `/citizen/settings`. Load each URL directly as well as by menu.

CIT-HOME, PROFILE

ID	Scenario	Steps	Expected result	Who is notified
CIT-001	Every page loads	1. Open each of the 17 URLs directly (full page load).	Each renders for the citizen, with the banner. A non-citizen role sees access-denied.	No one
CIT-002	Profile view/edit	1. Open Profile, edit an allowed field (`QA-`), save. 2. Try to edit the locked name.	Allowed fields save. Locked name cannot change (DB rule).	No one
CIT-003	Special categories	1. Add a special category (e.g. diabetes), then end it.	Card created; request statuses requested to card_issued (district review) per UI.	No one (tester to confirm)

CIT-ACCESS: Share and access

ID	Scenario	Steps	Expected result	Who is notified
CIT-010	Rotating key	1. Open Share & access. Watch the 6-digit key for 30 seconds.	Changes every 10 seconds; QR changes with it.	No one
CIT-011	Key is single use	1. Doctor tab opens the record with the current key. 2. Doctor tries the same key again.	Second try: "Key not recognised, already used or expired. Ask the patient for the new key." (Note: used-list is per server instance, so reuse may succeed on another instance: record it.)	Citizen: `record_opened` row exists but is not shown in Alerts (see Known Issues)
CIT-012	Live sessions	1. With a doctor session open, view live sessions.	Shows the doctor, mode, time left (max 30 min).	No one
CIT-013	Patient ends session	1. Click End on the live session. 2. In the doctor tab try to open files.	Doctor loses access (RLS). Doctor still sees only their own additions.	Doctor Arun Nair (direct) event `session-ended`
CIT-014	Report misuse	1. Report a session as misuse.	Review status becomes `pending`/`misuse` flow; shown in history.	No one (audit); tester to confirm admin visibility
CIT-015	History	1. Open access history.	All sessions listed with mode, ended_by, review. Cannot be edited.	No one
CIT-016	Share categories	1. Switch off lab, rx, vitals, imaging, genomic one by one. 2. As doctor try the matching data and AI tool.	Doctor gets 403 "The patient has not shared X with doctors". Allergies still appear in prescription safety checks.	No one
CIT-017	Emergency card cannot be off	1. Try to switch the emergency card (`emg`) off.	400, refused.	No one
CIT-018	Mental-health default	1. As doctor, open Anjali's documents with mental_health off. 2. Switch it on, repeat.	Hidden until on.	No one

ID	Scenario	Steps	Expected result	Who is notified
CIT-019	Family	1. Add a family member; 2. remove one; 3. view a member who has not accepted.	A family member who has not accepted cannot show the key.	No one (tester to confirm)

CIT-DOCS: Documents

ID	Scenario	Steps	Expected result	Who is notified
CIT-020	Folders	1. Create a folder `QA-folder`, rename it, archive it (colour change). 2. Try to archive a system folder; try to delete any folder.	Create/rename/colour/archive work; system folder cannot be archived; no delete.	No one
CIT-021	Upload allowed types	1. Upload a small PDF, JPEG, PNG, GIF, WebP, .docx, .txt, .csv, DICOM.	Each accepted; SHA-256 stored; appears in folder.	No one (audit)
CIT-022	Disallowed type	1. Upload .exe, .zip, .html.	400 "This file type is not allowed. Upload a PDF, image, Word, text, CSV or DICOM file."	No one
CIT-023	Fake extension	1. Rename a text file to `.pdf`; a .exe to `.png`.	400 "does not look like a real X file".	No one
CIT-024	Empty file	1. Upload a 0-byte file.	400 "The file is empty."	No one
CIT-025	Size limits	1. Upload 3 MB, 5 MB, 19 MB, 21 MB.	Code allows 20 MB, but the production host may reject bodies over about 4.5 MB: record exactly where it fails and the message.	No one
CIT-026	Download own	1. Download a document. 2. Edit the id in the URL to another person's document.	Own works (pre-signed link). Other person: 403 "Not your document".	No one
CIT-027	Immutability	1. Look for edit/delete on a document.	None. Move to another folder is allowed.	No one
CIT-028	AI summary hidden	1. Create an AI run as doctor but do not review. 2. Look for the summary in the citizen documents.	Not visible until the doctor reviews (and not if rejected).	Doctor review: no citizen event (tester to confirm)
CIT-029	Doctor-added documents	1. As doctor add a file to a session. 2. Look in the citizen documents/audit.	Citizen sees events on their own record (e.g. a lab upload).	Citizen (own record event)

CIT-DATES, VITALS

ID	Scenario	Steps	Expected result	Who is notified
CIT-030	Calendar	1. Open Dates; view upcoming.	Shows Wed 21 Oct 10:30 booking and the donor next-eligible date 2 Nov.	No one
CIT-031	Reminder	1. Add a reminder; edit it.	Saved and editable.	No one

ID	Scenario	Steps	Expected result	Who is notified
CIT-032	Calendar feed	1. Create the feed, open `/api/v1/calendar/<file>` without signing in, delete the feed, reopen.	Public by token while it exists; after delete the link fails.	No one
CIT-033	Normal reading	1. Add BP 120/80.	Saved; no alert.	No one
CIT-034	Hard-limit reading	1. Add BP 150/95 (smoke-test case). 2. Add a high blood sugar.	Saved; response `doctorNotified:true`.	Doctor on record (Dr. Arun Nair, direct) event `vitals`
CIT-035	Boundary readings	1. Try values just under and over each hard limit; negative; 0; text.	Boundaries behave as the limits say; invalid input rejected.	Only for over-limit values
CIT-036	Targets and summary	1. Change targets; reload summary.	Persisted.	No one

CIT-AI: AI chat

ID	Scenario	Steps	Expected result	Who is notified
CIT-040	Label	1. Start a chat; ask a general question.	Reply is labelled "simulated AI output"; never changes doses; no diagnosis.	No one
CIT-041	Red flag	1. Type "I have chest pain".	Chat stops and points to 108.	No one
CIT-042	Unreviewed results	1. Ask it to explain a result that no doctor has reviewed.	Refuses; only doctor-reviewed results are explained.	No one
CIT-043	Share with doctor	1. Share a chat to your doctor.	Works if a doctor has seen you. For a citizen with no doctor, 400 "No doctor who has seen you was found".	Doctor Arun Nair (direct) event `ai-chat-shared`
CIT-044	Sessions	1. Create several sessions; open an old one; send many messages.	Listed, retrievable, ordered.	No one

CIT-MSG, CARE

ID	Scenario	Steps	Expected result	Who is notified
CIT-050	Message treating doctor	1. Create a thread with Dr. Arun Nair; send a message.	Works.	Dr. Arun Nair (direct) event `message`
CIT-051	Non-treating doctor	1. Try a thread with a doctor who never treated you.	Refused (chat only with a treating doctor).	No one
CIT-052	Hospital/pharmacist thread	1. Thread with a hospital; a pharmacist thread with no patient named.	Hospital works; pharmacist thread must name a patient.	Hospital staff / pharmacist (tester to confirm recipient)
CIT-053	Read-only announcement	1. Open an announcement thread; try to reply.	403 "You cannot reply".	No one
CIT-054	Doctor reply	1. Doctor replies.	Appears in the citizen thread; unread count rises.	Citizen (direct) event `message`
CIT-060	Find care filters	1. Search by name; filter type, telemedicine, walk-in.	Only active doctors at active hospitals with find-care on.	No one

ID	Scenario	Steps	Expected result	Who is notified
CIT-061	Slots and booking	1. Pick a provider, slot; book.	Booking `confirmed`, ref `DEMO-APT-NNNNN`; visit token created (unique per doctor/day).	Doctor and Hospital admin of the slot's hospital, event `booking`
CIT-062	Past slot	1. Try to book a slot in the past (older than 17 Oct 14:45).	400 "slot is in the past".	No one
CIT-063	Hospital not taking bookings	1. Choose a hospital with bookings off.	400 "hospital is not taking bookings in the app".	No one
CIT-064	Double booking	1. Book the same slot again (or the existing Wed 21 Oct 10:30).	409 "already have a booking in this slot".	No one
CIT-065	Cancel	1. Cancel a future booking; try cancelling a started/completed one.	Future: cancelled and the linked Dates entry removed. Others refused.	Doctor and Hospital admin, event `booking`
CIT-066	Rebook cancelled	1. Book the slot you cancelled.	Re-confirmed (same row updated).	Doctor and Hospital admin
CIT-067	Past visits	1. Open past visits.	List shows completed visits.	No one

CIT-MED, BLOOD, ORGAN

ID	Scenario	Steps	Expected result	Who is notified
CIT-070	Today's doses	1. Tick a dose for today; then tick it again as skipped.	One of taken/skipped only; cannot change anything but the tick.	No one
CIT-071	Future dose	1. Tick a dose dated after 17 Oct.	400.	No one
CIT-072	Prescriptions, refills, queue	1. Open prescriptions; request a refill; view the pickup queue; use the medicine finder.	Data shown. Pickup status changes when the pharmacist marks ready/collected.	Citizen gets `dispensed` and `collected` events from the pharmacist
CIT-080	Donor availability	1. Switch availability on. Anjali donated 4 Aug, eligible 2 Nov.	400 "You are resting until ".	No one
CIT-081	Respond to a request	1. Respond to an open compatible request. 2. Try an incompatible group; a closed request.	OK; 400 "blood group cannot give to this request"; 400 "This request is closed".	Doctors of the hospital, event `blood-response`
CIT-082	Withdraw	1. Withdraw a response you did not make.	404. After responding, withdraw works.	No one (tester to confirm)
CIT-083	Camp pledge	1. Pledge to an open camp and a closed camp.	Open: ok. Closed: 400 "This camp is closed". Resting donor: 400.	No one
CIT-084	Checklist, banks, history	1. Fill the eligibility checklist; view banks; history.	Rules from the eligibility table apply (age, weight, gap).	No one
CIT-090	Organ pledge step 1	1. Choose organs.	Saved; status `intent`.	No one
CIT-091	Next of kin	1. Pick yourself. 2. Pick a family member.	400 "Pick a family member, not yourself"; second OK.	No one

ID	Scenario	Steps	Expected result	Who is notified
CIT-092	Witnesses	1. Invite 4 witnesses. 2. Invite yourself. 3. Remind; let a link expire.	Max 3 (400); self refused (400); expired link 400 until reminded.	No one
CIT-093	Witness signs	1. Sign as a witness; sign again.	First ok; second 409.	No one
CIT-094	Register rules	1. Try to register with 1 signed witness; with 2 and no relative; with 2 including a relative.	Needs 2 signed witnesses and at least one relative. Status `registered`. KNOS status is never set by the API ("Registered with KNOS" label only).	No one
CIT-095	Locked after registered	1. Change organs after registration.	409: withdraw first, then re-pledge.	No one
CIT-096	Signing desk	1. Choose a hospital with no organ desk; choose while still at `intent`.	400 both.	No one

CIT-REVIEW, COMPLAINT, ALERTS, SETTINGS

ID	Scenario	Steps	Expected result	Who is notified
CIT-100	Post review	1. Rate a hospital with text `QA-`.	Published (or pending moderation). One rating per hospital: a second gives an error.	Hospital admin (or pharmacy admin) event `review`
CIT-101	Helpful / report	1. Mark another review helpful; mark your own; report a review.	Own: 400. Others ok.	No one
CIT-102	Doctor reply	1. Doctor/hospital admin replies to your review.	Reply visible.	No one (tester to confirm)
CIT-110	File complaint	1. File a complaint against a hospital with a profile district.	Ref `CMP-NNNN`; 7-day reply deadline set.	Hospital admin (or pharmacy admin) event `complaint`, link `/hospital-admin/complaints`
CIT-111	Missing target	1. File with no hospital/pharmacy.	400.	No one
CIT-112	Add note / reopen	1. Add a note while open. 2. After the hospital resolves, add a note. 3. Reopen it. 4. Reopen an open one.	Note on open ok; on resolved 400; reopen only a resolved complaint.	Hospital admin on reopen, event `complaint`
CIT-113	Timeline	1. Open a complaint's timeline.	Append-only, in order.	No one
CIT-120	Alerts list	1. Open Alerts. Send an alert from the government console in each scope.	Citizen sees national, own state, own district alerts only.	See GOV rows
CIT-121	Preferences	1. Toggle each preference category and channel. 2. Turn off Emergency.	Saved; Emergency cannot be switched off (400). No real SMS/email is sent.	No one
CIT-122	Quiet hours / defaults	1. Check default channels (app + sms; monthly summary app/email/sms).	As stated.	No one
CIT-130	Settings	1. Change preferences. 2. View devices; revoke one; revoke others.	Persisted.	No one

ID	Scenario	Steps	Expected result	Who is notified
CIT-131	Data export	1. Request an export; poll.	Status requested, preparing, ready (or failed/expired).	No one
CIT-132	Delete request	1. Request deletion; cancel it.	Grace period (`grace_until`) shown; cancel restores. Do not leave a live deletion request.	No one
CIT-133	Guardian view	1. If a guardian account with a minor exists, open the minor's events.	A guardian sees a minor's events. (Seed minors have no login; tester to confirm.)	Guardian

Part B: Doctor, Nurse, Lab, Radiology, Pharmacist and end-to-end flows

All rows use the demo people from the Start-here page. Doctor pages are in `/doctor?section=...` with sections: home, open, session, schedule, messages, rx, orders, referral, emergency, donors, stock, profile, settings.

DOC-OPEN: opening a patient, sessions, queue

ID	Scenario	Steps	Expected result	Who is notified
DOC-001	Home	1. Sign in as Dr. Arun Nair. Open home.	Queue, alerts and notifications load with the banner.	No one
DOC-002	Open with valid key	1. Citizen tab: open Share & access. 2. Doctor tab: Open patient, enter the patient's ABHA number (`DEMO-0000-1234`) and the current 6-digit key (or paste the QR text, which needs no ABHA number).	Session opens (key mode, max 30 min). Today's visit (booked/checked_in/waiting) moves to `in_consultation`.	Citizen: `record_opened` push row (not shown in Alerts; see Known Issues). Audit `session.open`
DOC-003	Expired key	1. Copy a key, wait 25 seconds, enter it.	"Key not recognised, already used or expired. Ask the patient for the new key."	No one
DOC-004	Previous window	1. Enter a key within 10 seconds after it rotated.	Accepted (current and previous window are valid).	As DOC-002
DOC-005	Reused key	1. Use the same key twice.	Second refused with the generic message (may succeed on another server instance: record it).	No one
DOC-006	Wrong / malformed key	1. Enter `12345`, `abcdef`, `000000`.	Generic message, no hint whether it exists.	No one
DOC-006a	ABHA number required for a typed key	1. Leave the ABHA field empty and enter a valid key. 2. Enter a wrong ABHA number with a valid key. 3. Enter another patient's key with Anjali's ABHA number.	1: the form asks for the ABHA number. 2 and 3: the generic message "Key not recognised, already used or expired..." (no hint which part was wrong).	No one
DOC-006b	Lockout after wrong keys	1. Enter 5 wrong keys in a row from the same doctor tab. 2. Enter a 6th (even a correct one). 3. Wait about 10 minutes and retry.	After 5 wrong keys: 429 "Too many wrong keys. Wait about 10 minutes, then ask the patient for the new key." Locked per doctor and address. After the window it works. A correct key clears the count. Shared demo doctor: tell other testers before testing this.	No one
DOC-007	Ambiguous code	1. (Hard to force) note if two citizens ever share a 6-digit code.	Refused with the generic message.	No one
DOC-008	One live doctor per patient	1. With a session open, ask a second doctor tab (another doctor) to open the same patient.	Refused (one live doctor session per patient).	No one

ID	Scenario	Steps	Expected result	Who is notified
DOC-009	Nurse cannot use key	1. As Lekha Pillai call `POST /doctor/access/open` or look for the key box in `/nurse`.	Refused (403 or not offered).	No one
DOC-010	Own record	1. As Dr. Nair try to open his own citizen identity.	403 (DB rule and API).	No one
DOC-011	Geofence	1. Open with a location far (>~5 km) from the hospital and no reason. 2. Repeat with a reason.	Without reason: 400. With reason: opens. Location is optional; checked only at open (5-minute re-check not built).	No one (audit)
DOC-012	30-minute cap	1. Open a session and look at the timer. 2. Wait or check the expiry value.	Never more than 30 minutes. Expired sessions end as `timeout` on the next request.	No one
DOC-013	End session by doctor	1. Click End session.	Session ended (`ended_by` doctor); doctor loses record view but keeps their own additions under past patients.	Citizen sees it in access history (no event)
DOC-014	Patient ends mid-consult	1. Citizen ends the session while the doctor views a file.	Next doctor request fails (access lost).	Dr. Nair (direct) `session-ended`
DOC-015	Session view	1. Open session; view summary, trends, files, a file's download.	Respects the share categories.	No one
DOC-016	Queue transitions	1. In the queue set a booked visit to waiting, then done; a waiting one to no_show; try done on a `booked` one; try `cancelled`.	Allowed: waiting from booked/checked_in; no_show from booked/checked_in/waiting; done from in_consultation/checked_in/waiting. Others: 403 "A visit that is X cannot be set to Y".	No one
DOC-017	Waiting tone	1. Look at a visit waiting 15+ minutes.	Warning tone.	No one
DOC-018	Past patients and my additions	1. Open past patients; open one's my-additions.	Only things this doctor added.	No one
DOC-019	Schedule	1. Open schedule.	Today (17 Oct) and booking Wed 21 Oct 10:30 token 16 shown.	No one

DOC-AI: AI tools and review

ID	Scenario	Steps	Expected result	Who is notified
DOC-020	AI chat	1. In an open session run the AI chat.	Result labelled "Simulated AI output. Guidance only." Status is VERIFIED, SUPPORTED_WITH_CAUTION or UNCERTAIN (agreement 1 / 0.67 / 0.33) with three model votes (sim-model-a, b, c) and a disagreement report. Same input gives the same output.	No one (audit `ai.chat`)
DOC-021	Image tool	1. Run the image tool on a patient with a scan; then on one with none.	With scan: result. Without: 404.	No one

ID	Scenario	Steps	Expected result	Who is notified
DOC-022	Genomic and temporal	1. Run each tool. 2. Switch genomic sharing off as the citizen and rerun.	403 "The patient has not shared genomic with doctors".	No one
DOC-023	AI switched off	1. (Central admin only, with Athun's agreement) turn the AI flag off. 2. Run a tool.	503 "AI features are switched off by the platform administrator". Turn it back on.	No one
DOC-024	Chat needs a session	1. Call clinical-assist chat with no open session.	Refused (DB rule).	No one
DOC-025	Review accept	1. Review an AI run: accept.	Verdict `agree`; visible to the citizen.	No one
DOC-026	Review edit	1. Edit with empty text; then with text.	Empty refused; with text saved as `edited`; visible to citizen.	No one
DOC-027	Review reject	1. Reject a run.	Verdict `disagree`; hidden from the citizen.	No one
DOC-028	Second review	1. Review the same run again.	409 "already been reviewed".	No one
DOC-029	Citizen-guidance chat review	1. Try to review a citizen AI chat.	403.	No one
DOC-030	Results are locked	1. Try to alter a stored AI result.	Not possible in UI; API refuses.	No one
DOC-031	Patient visibility	1. After each of DOC-025/026/027 check the citizen documents.	agree/edited visible; disagree hidden; unreviewed hidden.	No one

DOC-RX: prescriptions

ID	Scenario	Steps	Expected result	Who is notified
DOC-040	Medicine search	1. Open Rx; search a medicine.	Matching medicines.	No one
DOC-041	Safe prescription	1. Add a medicine, run Check; draft; sign.	Check passes; signed; number `RX-DEMO-NNNNN`; valid 30 days; signature `DEMO-ESIGN-...` marked simulated.	Pharmacist (if pharmacy linked) and Citizen, event `prescription`
DOC-042	Allergy conflict	1. Add a medicine the patient is allergic to; run Check; try to sign.	Status "blocked". Sign gives 409 "Blocked: the patient is allergic ... or give an override reason". With a reason it signs. Allergies are checked even if sharing is off.	Same as DOC-041 on success
DOC-043	Interaction	1. Add two interacting drugs (major/contraindicated); sign without a reason, then with one.	409 without; ok with reason.	Same

ID	Scenario	Steps	Expected result	Who is notified
DOC-044	Stock status	1. Add medicines that are in stock, low, out.	Check shows in / low / out / unknown.	No one
DOC-045	Kidney note	1. Prescribe for a patient with low eGFR.	eGFR note shown.	No one
DOC-046	Empty / re-sign	1. Sign with no medicines. 2. Sign a draft twice.	400 "Add at least one medicine"; 404 draft not found or already signed.	No one
DOC-047	e-Sign failure	1. Not testable with the demo doctor (all demo HPR ids succeed).	Note only.	No one
DOC-048	Immutable	1. Try to change a signed prescription.	Not possible.	No one
DOC-049	Prescription list	1. Open the list and a prescription.	Shows status issued, then partly_dispensed or dispensed after the pharmacist works.	No one

DOC-ORD: orders, referrals, handover, messages, emergency

ID	Scenario	Steps	Expected result	Who is notified
DOC-050	Lab order	1. In a session order a CBC.	Ref `ORD-DEMO-NNNN`, status open.	Lab technicians of the hospital and the Citizen, event `lab-order`
DOC-051	Imaging order	1. Order a CT/X-ray.	Created.	Radiology techs of the hospital and the Citizen, event `imaging-order`
DOC-052	Unknown test/study	1. Call orders with an unknown test code / study.	400.	No one
DOC-053	Ack result	1. After the lab releases, acknowledge the result.	Result marked acknowledged.	No one
DOC-054	Referral create	1. Refer a patient to another hospital (not own) and a doctor there.	Created, status `sent`.	Citizen and Hospital admin (sender's hospital), plus the receiving doctor (direct), event `referral`
DOC-055	Referral target checks	1. Choose an inactive hospital; a doctor who does not work there.	400 both.	No one
DOC-056	Referral progress	1. As the receiving doctor mark seen, accepted, closed. 2. Try backwards or skip. 3. As another doctor try to update.	Forward only (400 "The referral is already X"); only receiver (403).	Citizen, Hospital admin (tester to confirm)
DOC-057	Handover	1. Create a handover for treated patients to a colleague; sign it as the colleague. 2. Sign as someone else; sign twice; hand over an untreated patient.	Create notifies; only named recipient signs (403 otherwise); double sign 400/409; untreated patient 403; signed handover immutable.	Doctors and nurses of the hospital on create, event `handover`; author on sign
DOC-058	Messages	1. Reply to a citizen message.	Appears for citizen.	Citizen (direct) `message`
DOC-059	Donors and blood request	1. Open donors; create a blood request (normal/urgent/critical).	Request open.	Citizens and the District admin role, event `blood-request`
DOC-060	Pharmacy stock view	1. Open stock.	Read-only hospital pharmacy stock.	No one

ID	Scenario	Steps	Expected result	Who is notified
DOC-061	Profile, settings, reviews	1. Edit profile and settings; reply to a review.	Saved.	No one
DOC-062	Emergency lookup	1. Look up ABHA `DEMO-0000-1234`; then an unknown ABHA.	Found; unknown: 404 "No patient with that ABHA number".	No one
DOC-063	Emergency card window	1. Open the card.	Window is 15 minutes (citizen screen text says 60: known conflict).	No one
DOC-064	Break-glass start	1. Emergency, break-glass: reason under 20 characters; no second doctor; the same doctor as confirmer; a doctor of another hospital; a valid second doctor of the same hospital.	Only the last works. Window 15 min, read-only card.	Hospital admin and the Citizen, event `break-glass` (citizen title "Emergency access used"; no other patient's names). Confirming doctor: tester to confirm
DOC-065	Break-glass off	1. (With Athun) central admin turns `bg` off.	403 "switched off by the platform administrator". Turn back on.	No one
DOC-066	Unidentified patient	1. Break-glass for an unidentified person with no label/age; then with both.	Both required. Patient not notified (unidentified); emergency contact notified if one exists.	Hospital admin
DOC-067	Hospital review	1. As Dr. Meera Krishnan open Break-glass; justify one, escalate another.	One review per case; 72-hour window; status open, justified or escalated; only that hospital's admin (or a visiting posting).	No one (audit)

NURSE (Lekha Pillai, `/nurse`)

ID	Scenario	Steps	Expected result	Who is notified
NUR-001	Ward board	1. Open home.	Ward 3 beds; Thomas Kurian Bed 7, NEWS 7.	No one
NUR-002	Vitals low score	1. Record normal vitals.	NEWS2 low; no escalation.	No one
NUR-003	Score 5 or 6	1. Record vitals that score 5-6.	Medium; ward-doctor escalation.	Doctors of the hospital, event `vitals-critical`
NUR-004	Score 7 or more	1. Record vitals scoring 7+.	High; rapid-response escalation.	Doctors of the hospital, event `vitals-critical`
NUR-005	Single parameter 3	1. One parameter scoring 3, rest normal.	low_medium.	No one (tester to confirm)
NUR-006	Vitals immutable	1. Try to edit a recorded set; mark an error.	Only an error flag can be set.	No one
NUR-007	Discharged patient	1. Record vitals or a task for a discharged patient.	409.	No one
NUR-008	Notes and tasks	1. Add a note; create a task; assign to a nurse of another hospital; complete it.	Same-hospital assignee only; done works.	No one

ID	Scenario	Steps	Expected result	Who is notified
NUR-009	MAR	1. Administer a dose at a scheduled time; at a non-scheduled time; again; withhold without a reason; withhold with a reason.	Wrong time 400; duplicate 409; withheld needs a reason; MAR rows are immutable; order must be active.	No one
NUR-010	Orders	1. Accept, reject (no reason, then with), complete a nursing order.	Rejected needs a reason.	Ordering doctor (direct) `message` on reject
NUR-011	Handover	1. Create a handover; recipient signs; sign by another; edit after signing.	As DOC-057; items can be ticked done.	Recipient on create; author on sign (event `handover`)
NUR-012	Ward stock	1. Open ward stock for a nurse with and without a ward. Raise a request; count.	Without a ward 400.	Pharmacist (ward request) tester to confirm
NUR-013	Alerts and escalations	1. Acknowledge an alert and an escalation; acknowledge again.	Second: 409 "Already acknowledged".	No one
NUR-014	Admission mode	1. Open Admission mode; view a bed.	Details per bed.	No one

LAB (Rahul Varghese, `/lab-tech`)

ID	Scenario	Steps	Expected result	Who is notified
LAB-001	Worklist	1. Open worklist after DOC-050.	Order shown.	No one
LAB-002	Accept / reject	1. Accept an open order; reject another (no reason, then with).	open to accepted; reject from open or accepted, reason required.	Ordering doctor (direct) `message` on decline
LAB-003	Specimens	1. Mark collected; receive; reject a specimen.	Receive only when `collected`. Statuses pending, collected, in_lab, rejected, done.	Ordering doctor on specimen rejection
LAB-004	Enter and verify	1. Enter a result (draft or preliminary); verify.	Only draft/preliminary can be verified. Range comes from the catalogue; delta vs last released value shown.	No one
LAB-005	Release	1. Release a verified result; try releasing an unverified one.	409 "Verify the result before releasing it".	Ordering doctor (direct, role doctor) and a separate copy to the Citizen, event `lab-result` "Result ready"
LAB-006	Immutable	1. Edit or delete a released result.	Impossible (use an amended result).	No one
LAB-007	Critical value	1. Enter a value beyond the critical limit.	Flag HH / critical; appears in the critical box until the call is logged.	Ordering doctor (direct) event `lab-result` "CRITICAL value"
LAB-008	Critical call	1. Log a call to a doctor or nurse of the same hospital; another hospital's doctor; confirm read-back twice.	Same hospital ok; other 400; read-back once only (409 second time).	No one
LAB-009	Citizen visibility	1. As Anjali view results at each stage.	Citizen sees only released results; doctors of another hospital see none.	No one

ID	Scenario	Steps	Expected result	Who is notified
LAB-010	QC, instruments, lots	1. Add a QC run; set an instrument ok/calibrating/down/retired; view reagent lots (in_use, expired, quarantined, empty).	Saved and listed; TAT screen shows.	No one
LAB-011	Handover	1. Create and sign a lab handover.	As NUR-011.	Recipient / author, event `handover`
LAB-012	Catalogue	1. Check NEUT, UCULT and ABG tests exist; NEUT in CBC.	Present.	No one

RAD (Fathima Beevi, `/radiology-tech`)

ID	Scenario	Steps	Expected result	Who is notified
RAD-001	Worklist and accept/reject	1. Open worklist after DOC-051; accept; reject another (reason).	Works.	Ordering doctor on decline
RAD-002	Schedule/start	1. Schedule and start a study; use a room that is down or the wrong modality.	Start only from waiting/scheduled; down room 409 "out of service"; wrong modality 400.	No one
RAD-003	Upload	1. Upload before start; after start.	Before: 409. After: ok (status `uploaded`).	No one
RAD-004	Withdraw file	1. Withdraw within 24 hours with a reason; after 24 hours; twice.	Within: ok; after: refused; second: refused.	No one
RAD-005	Checklist and exposure	1. Fill checklist and exposure.	Saved.	No one
RAD-006	Priors	1. Add a prior study of the same patient, then another patient's.	Own ok; other refused.	No one
RAD-007	Submit	1. Submit with unresolved checklist problems; resolved; from a wrong status.	Problems give 409 `problems`; only from in_progress/uploaded.	Ordering doctor, event `imaging-result` "Images ready" (when reported)
RAD-008	Reported is final	1. Edit a reported study.	Refused ("ask the reporting doctor").	No one
RAD-009	Citizen visibility	1. Citizen views the study before and after `reported`.	Visible only after reported.	No one
RAD-010	Rooms, equipment	1. Change room status ok/down/maintenance; log an equipment event.	Saved.	No one
RAD-011	Handover	1. Create and sign.	As NUR-011.	Recipient / author, event `handover`

PHARM (Joseph Mathew, `/pharmacist`)

ID	Scenario	Steps	Expected result	Who is notified
PHM-001	Queue and scan	1. Open queue; scan a prescription QR.	Prescription found by QR.	No one
PHM-002	Verify	1. Verify a clean prescription; one with a blocking check.	Clean: ok. Blocking: 409.	No one

ID	Scenario	Steps	Expected result	Who is notified
PHM-003	Dispense before verify	1. Dispense an unverified prescription.	409.	No one
PHM-004	Dispense outcomes	1. Dispense normally; as substitute; as out_of_stock.	Each recorded; stock reduces; a stock-ledger row is written (immutable).	No one
PHM-005	Over-dispense	1. Dispense more than stock; dispense an already fully dispensed item.	Refused; 409 "already fully dispensed".	No one
PHM-006	Substitutes	1. Choose a not-allowed substitute; a therapeutic swap without agreement; with `prescriberAgreed`.	Only allowed substitutes; therapeutic swap needs prescriber agreement.	Prescribing doctor via pharmacy note, event `message`
PHM-007	FEFO	1. Dispense a later-expiring batch while an earlier one exists.	Needs an override reason.	No one
PHM-008	Recalled/blocked batch	1. Look for a recalled batch in stock finder and dispense.	Hidden from finder; cannot be dispensed.	No one
PHM-009	Partial and top-up	1. Dispense part, then top up.	Status `partly_dispensed`, then `dispensed`.	No one
PHM-010	Ready	1. Mark ready before verification or with nothing dispensed; then properly; then again.	First refused; ok; second 409.	Citizen, event `dispensed`
PHM-011	Handover QR and collected	1. Show the handover QR. 2. Mark collected with a wrong code; with the right code (`CFHO		`); before ready.`
PHM-012	History, refills	1. Open patient history and refills.	Shown.	No one
PHM-013	Stock actions	1. Adjust stock (zero, positive, negative, negative beyond stock); write off without and with a reason.	Zero refused; write-off needs a reason; no negative stock.	No one
PHM-014	Expiry, log, export	1. Open expiry and dispensing log; export CSV.	Lists; CSV downloads.	No one
PHM-015	Recalls	1. Confirm a recall; confirm again.	Second: 409 "Already confirmed off shelf".	No one
PHM-016	Ward requests	1. Decide a ward request with enough, then not enough stock; decide again.	"Not enough stock to issue (N short)"; "Request is already X".	Nurse (tester to confirm)
PHM-017	Controlled drugs	1. Dispense an H, H1, X item.	Controlled-drug register entry.	No one
PHM-018	Pharmacist note	1. Send a pharmacy note on a prescription.	Delivered.	Prescribing doctor, event `message`

E2E: end-to-end chains across roles

Use one browser tab per role. "Who is notified" lists the alert at every step.

ID	Scenario	Steps	Expected result	Who is notified
E2E-001	Consultation to lab result	1. Citizen books a slot. 2. Doctor sees it in the queue, opens the record with the key. 3. Doctor orders a CBC. 4. Lab accepts, marks collected, enters, verifies, releases. 5. Doctor acknowledges. 6. Citizen opens the result.	Each step succeeds; citizen sees only the released result.	1: Doctor + Hospital admin (`booking`). 3: Lab + Citizen (`lab-order`). 4 release: Doctor + Citizen (`lab-result`). 5: nobody
E2E-002	Critical lab	1. As E2E-001 but enter a critical value; release; log the critical call with read-back.	Critical box clears after the call is logged.	Doctor (direct) "CRITICAL value", then Doctor + Citizen "Result ready" on release
E2E-003	AI imaging	1. Doctor runs the image tool; reviews as accept. 2. Citizen checks documents. 3. Repeat with reject.	Visible after accept; hidden after reject.	None for AI; audit `ai.image`, `ai.review`
E2E-004	Prescription to collection	1. Doctor signs an Rx. 2. Pharmacist scans, verifies, dispenses, marks ready. 3. Citizen sees the pickup queue and shows the QR. 4. Pharmacist marks collected.	Statuses issued, dispensed; fulfilment times filled.	1: Pharmacist + Citizen (`prescription`). 2 ready: Citizen (`dispensed`). 4: Citizen (`collected`)
E2E-005	NEWS2 escalation	1. Nurse records vitals scoring 7+.	Rapid-response escalation.	Doctors of the hospital (`vitals-critical`)
E2E-006	Referral	1. Doctor A refers to Doctor B at another hospital. 2. B marks seen, accepted, closed.	Forward only.	Citizen, Hospital admin, Doctor B (`referral`)
E2E-007	Break-glass	1. Doctor opens break-glass with a second doctor. 2. Hospital admin justifies.	15-minute window; review within 72 hours.	Hospital admin + Citizen (`break-glass`)
E2E-008	Blood request	1. Doctor creates an urgent blood request. 2. A compatible donor citizen responds. 3. District admin sends "notify donors".	Responses visible to doctors.	1: Citizens + District admin (`blood-request`). 2: Doctors of the hospital (`blood-response`)
E2E-009	Imaging order to report	1. Doctor orders imaging. 2. Radiology accepts, schedules, starts, uploads, submits. 3. Doctor opens the images; citizen views.	Citizen sees only after reported.	1: Radiology + Citizen (`imaging-order`). 2 report: Doctor (`imaging-result`)
E2E-010	Handover	1. Nurse hands over to a colleague nurse; colleague signs.	Immutable after signing.	Colleague, then the author (`handover`)
E2E-011	Citizen to doctor messages	1. Citizen messages doctor. 2. Doctor replies.	Thread updates both sides.	Doctor (`message`), then Citizen (`message`)

ID	Scenario	Steps	Expected result	Who is notified
E2E-012	Patient ends session	1. Doctor has a session open. 2. Citizen ends it.	Doctor loses access immediately.	Doctor (`session-ended`)
E2E-013	Complaint and review	1. Citizen files a complaint and a review. 2. Hospital admin assigns and resolves the complaint; replies to the review. 3. Citizen reopens.	Statuses open, assigned, resolved, reopened; 7-day deadline.	Hospital admin (`complaint`, `review`); on reopen again Hospital admin
E2E-014	Booking to cancel	1. Citizen books, then cancels.	Dates entry created and removed.	Doctor + Hospital admin both times (`booking`)
E2E-015	Home reading	1. Citizen logs BP 150/95.	Doctor alerted.	Dr. Arun Nair (`vitals`)
E2E-016	Registration to approval	1. Register a doctor. 2. District admin approves.	Account goes pending to active.	None (district inbox; audit)
E2E-017	Health alert	1. District/State admin creates a health alert for Kerala. 2. Citizen opens Alerts.	Citizen in scope sees it.	Citizens in scope (health alert feed)

Part C: Pharmacy admin, hospital admin, government consoles, notifications, access control, safety, security

PHARMACY-ADMIN

Persona: Suma Thomas (PHARMACY_ADMIN), screen `/pharmacy-admin` with sections overview, staff, inventory, orders, expiry, compliance, governance, audit. Every action is limited to the admin's own pharmacy and writes a pharmacy-scoped audit entry. None of these actions emits an in-app event.

ID	Scenario	Steps	Expected result	Who is notified
PA-001	Overview loads	1. Sign in as Suma Thomas at `/demo-signin`. 2. Open `/pharmacy-admin?section=overview`.	Page loads with KPI tiles and no error banner. "SYNTHETIC DEMO DATA" banner is visible.	No one
PA-002	Pharmacist list ordering and filter	1. Open the Staff section. 2. Note the order of rows. 3. Type part of a name in the search box (API `q`, max 80 characters).	Active pharmacists are listed first, then others, each group by name. Search matches by name, case-insensitive. KPI counts (active, pending invites) match the rows.	No one
PA-003	Deactivate an active pharmacist	1. In Staff pick an active pharmacist. 2. Choose Deactivate and enter reason "Left the pharmacy" (3 to 300 characters). 3. Confirm.	Status becomes `deactivated`, reason shown, `deactivated_at` set. Audit tab (group staff) shows `staff.deactivate` with the reason.	No one (audit entry only)
PA-004	Deactivate reason too short	1. Repeat PA-003 but enter reason "ab". 2. Or call `POST /api/v1/pharmacy-admin/pharmacists/:userId/deactivate` with `{"reason":"ab"}`.	400 `Invalid request` with an issue on `reason`. Status unchanged.	No one
PA-005	Deactivate an already deactivated pharmacist	1. Pick the deactivated pharmacist (seeded: Bindu Varghese, if she belongs to this pharmacy; tester to confirm). 2. Call the deactivate endpoint with a valid reason.	409 `Only an active account can be deactivated.`	No one
PA-006	Reactivate a deactivated pharmacist	1. Pick a deactivated pharmacist. 2. Choose Reactivate and confirm.	Status `active`, reason cleared. Audit shows `staff.reactivate`. Restore: deactivate again if you changed seeded state.	No one (audit entry only)
PA-007	Reactivate an active pharmacist	1. Call `POST .../pharmacists/:userId/reactivate` for an active pharmacist.	409 `Only a deactivated account can be reactivated.`	No one

ID	Scenario	Steps	Expected result	Who is notified
PA-008	Another pharmacy's pharmacist	1. Take a pharmacist user id from a different pharmacy (ask Athun). 2. Call deactivate with a valid reason.	404 `Pharmacist not found in your pharmacy.` Nothing changes.	No one
PA-009	Create pharmacist (boundary on registration number)	1. Call `POST /api/v1/pharmacy-admin/pharmacists` with a valid `personId` (UUID) and `registrationNo` of 2 characters. 2. Repeat with 3 characters and 61 characters. 3. Repeat with `personId` "abc".	2 characters: 400 `Invalid request`. 3 characters: accepted if the person is valid (account is `active` at once, no activation step). 61 characters: 400. Bad UUID: 400. Tester to confirm the message for an unknown person.	No one (audit entry only)
PA-010	Invite a pharmacist	1. Staff > Invite. 2. Enter name "Test Invitee", a fake address `test.invitee@example.invalid`, registration number "KL-PH-0001", shift day. 3. Submit.	Invite appears under pending invites with 7-day expiry. The response has `mockActivationLink` on `demo.carefusion.invalid`. Audit `staff.invite`.	No one (audit entry only)
PA-011	Duplicate open invite	1. Repeat PA-010 with the same email (any letter case).	409 `This person already has an open invite.`	No one
PA-012	Invite validation	1. Submit an invite with email `not-an-email`. 2. Submit with a 1-character name. 3. Submit with shift "weekend".	Each gives 400 `Invalid request`. Allowed shifts are day, night, rotating.	No one
PA-013	Resend and revoke invite	1. Resend the invite from PA-010. 2. Revoke it. 3. Try to resend it again.	Resend raises the resend count and audit `staff.invite_resent`. Revoke removes it from the pending list, audit `staff.invite_revoked`. Third step: 409 `This invite is no longer open.`	No one (audit entry only)
PA-014	Unknown invite id	1. Call `POST .../invites/<random UUID>/resend`.	404 `Invite not found in your pharmacy.`	No one
PA-015	Invite link goes nowhere	1. Open the `mockActivationLink` URL.	The `.invalid` host cannot load. There is no invite-accept screen in the alpha (known gap). `/staff/activate` only signs in as the demo nurse.	No one
PA-016	Inventory filters and paging	1. Open Inventory. 2. Switch filter between all, low, hidden, blocked. 3. Use category and search. 4. Call the API with `limit=201`.	Each filter narrows the list correctly. `limit=201` gives 400 `Invalid request` (limit is 1 to 200).	No one
PA-017	Hide and show a batch	1. Pick a published, unblocked batch. 2. Toggle it hidden, then shown.	`is_published` flips each time. Audit `stock.publish` ("hidden from" / "shown in" public finder). Citizen medicine finder reflects it.	No one (audit entry only)

ID	Scenario	Steps	Expected result	Who is notified
PA-018	Publish a blocked batch (blocked)	1. Filter `blocked`. 2. Try to show a blocked batch in the public finder.	409 `This batch is blocked (<reason>) and cannot be shown in the public finder.` where reason is the stored block reason (for example `Recall ...`). Batch stays hidden.	No one
PA-019	Adjust stock: write-off within stock	1. Pick a batch with at least 5 on hand. 2. Adjust type write_off, quantity 1, reason "Damaged in storage".	On-hand quantity falls by 1. A stock ledger row is written (cannot be edited later). Audit `stock.adjust`.	No one (audit entry only)
PA-020	Adjust stock: more than on hand	1. Pick a batch with N on hand. 2. Adjust type write_off with quantity N+1.	400 `Not enough stock. N on hand.` Stock unchanged.	No one
PA-021	Adjust stock boundary and validation	1. Adjust with quantity 0. 2. Adjust with quantity -1. 3. Adjust with reason "ab". 4. Adjust with type "gift".	All four give 400 `Invalid request`. Quantity must be above 0 and at most 1,000,000. Reason 3 to 300 characters. Types: adjustment, write_off, return_to_supplier, quarantine.	No one
PA-022	Adjust stock upward	1. Adjust type `adjustment`, direction `in`, quantity 2, reason "Count correction". 2. Repeat with type write_off and direction `in`.	First: quantity rises by 2. Second: the direction is ignored for non-adjustment types and the quantity falls (code treats only `adjustment` + `in` as an increase). Tester to confirm the UI exposes direction.	No one (audit entry only)
PA-023	Adjust another pharmacy's batch	1. Call `POST .../inventory/<batch id of another pharmacy>/adjust` with valid input.	404 `Stock batch not found in your pharmacy.`	No one
PA-024	Raise PO at or below the threshold	1. Orders > New order. 2. Pick a supplier and 1 medicine so the total is exactly Rs 1,00,000 (quantity x unit cost). 3. Submit.	Response has `status: approved` (the threshold is "greater than Rs 1,00,000"). PO number matches `PO-YYYY-NNNN`. Audit `stock.po_raised`.	No one (audit entry only)
PA-025	Raise PO above the threshold	1. Raise a PO with total Rs 1,00,001. 2. Open it in the list.	Status `pending_approval`, flag `needsApproval: true`. The raising admin sees it waiting for a different approver.	No one (audit entry only)
PA-026	PO validation: duplicate medicine, unknown supplier, empty lines	1. Raise a PO with the same medicine on two lines. 2. Raise a PO with a random supplier UUID. 3. Raise a PO with zero lines, then 201 lines, then quantity 0, then unit cost -1.	1: 400 `Each medicine can appear only once in an order.` 2: 400 `Supplier not found.` 3: each 400 `Invalid request` (lines 1 to 200, quantity above 0, cost 0 or more).	No one
PA-027	Approve own PO	1. As Suma, open the PO from PA-025 (raised by Suma). 2. Click Approve.	409 `The person who raised an order cannot approve it.` Status stays `pending_approval`.	No one

ID	Scenario	Steps	Expected result	Who is notified
PA-028	Approve a PO raised by someone else	1. Ask Athun for a seeded `pending_approval` PO raised by another user (tester to confirm one exists). 2. As Suma, open it and Approve.	Status `approved`, approver and time set, hold reason cleared. Audit `stock.po_approved`.	No one (audit entry only)
PA-029	Approve a PO that is not waiting	1. Approve the PO from PA-028 again, or approve an `approved` PO such as the one from PA-024.	409 `This order is not waiting for approval.`	No one
PA-030	Send back (hold) a PO	1. Open a `pending_approval` PO raised by someone else. 2. Send back with reason "Price too high".	Status `held`, hold reason stored. Audit `stock.po_held` naming the raiser and the reason.	No one (audit entry only)
PA-031	Send back without reason, or on a wrong state	1. Send back with empty reason or "ab". 2. Send back an `approved` PO.	1: 400 `Invalid request` (reason 3 to 300 characters). 2: 409 `This order is not waiting for approval.`	No one
PA-032	PO states beyond approved	1. In the list filter by each status: draft, pending_approval, approved, held, sent, in_transit, received, cancelled. 2. Look for any button that moves a PO to sent, in_transit, received or cancelled. 3. Call `GET .../purchase-orders?status=shipped`.	Filter works for the 8 statuses. The API has no endpoint to move a PO to sent, in_transit, received or cancelled, so those states exist only in seeded data (tester to confirm; report any button that appears to do it). `draft` is only a moment during creation. `status=shipped` gives 400.	No one
PA-033	PO of another pharmacy	1. Call `GET .../purchase-orders/<PO id of another pharmacy>`.	404 `Purchase order not found in your pharmacy.`	No one
PA-034	Suppliers list	1. Open the PO form supplier drop-down or `GET .../suppliers`.	Only active suppliers, sorted by name, each with a kind.	No one
PA-035	Recall: confirm off shelf	1. Governance (recalls) > pick a recall with status `action_needed`. 2. Confirm off shelf with a note (max 300 characters).	Status `confirmed_off_shelf` with confirmer and time. For a non-notice recall with a batch number, matching batches in this pharmacy become blocked ("Recall ") and hidden. Audit `stock.recall_confirmed`.	No one (audit entry only)
PA-036	Recall: confirm twice	1. Confirm the recall from PA-035 again.	409 `Already confirmed off shelf.`	No one
PA-037	Recall: undo	1. Undo the confirmation from PA-035. 2. Check the same batch in Inventory > blocked.	Status returns to `action_needed` (or `review` for a notice-class recall). The batch stays blocked: only a central recall action lifts a block. Audit `stock.recall_unconfirmed`.	No one (audit entry only)
PA-038	Recall: undo when not confirmed, foreign recall	1. Undo a recall that is `action_needed`. 2. Confirm a recall id that was never sent to this pharmacy.	1: 409 `Nothing to undo: this recall is not confirmed.` 2: 404 `This recall does not apply to your pharmacy.`	No one

ID	Scenario	Steps	Expected result	Who is notified
PA-039	Recall statuses on screen	1. Open the recall list. 2. Find rows with `review` and `not_stocked` status.	All four statuses appear where seeded: action_needed, review, confirmed_off_shelf, not_stocked. A `not_stocked` row offers no shelf action (tester to confirm).	No one
PA-040	Expiry view	1. Open the Expiry section.	Batches near or past expiry are listed with days left. Tester to confirm the buckets and that the DEMO_NOW date is used, not the real date.	No one
PA-041	Compliance documents list and expiry status	1. Open Compliance. 2. Find a document whose `validUntil` is in the past but whose stored status is verified, renew_soon or upcoming.	The screen shows it as `expired` (the API upgrades the status when days left is negative). Other statuses shown as stored: verified, under_review, renew_soon, expired, upcoming, rejected.	No one
PA-042	Licence expiry warning	1. Look at the compliance page for the drug licence. 2. Seed note: pharmacy admin Ancy Varghese's licence expires in 20 days.	A warning (renew soon) shows for a licence ending within the warning window. Tester to confirm which pharmacy shows it and the window length.	No one
PA-043	Add a compliance document	1. Compliance > Add document. 2. Enter type "licence", title "Test licence copy", reference "TEST-1", valid from 2026-01-01, valid until 2027-01-01. 3. Submit.	New document with status `under_review`. Audit `stock.document_uploaded`.	No one (audit entry only)
PA-044	Compliance validation and no delete	1. Add a document with valid-from "01/01/2026". 2. Add one with a 1-character title. 3. Try `DELETE /api/v1/pharmacy-admin/compliance/documents/<id>`.	1: 400 with issue `Use YYYY-MM-DD`. 2: 400 `Invalid request`. 3: 404 (no such route). Documents can never be deleted; only the status can change (DB rule).	No one
PA-045	Audit log filters and paging	1. Open Audit. 2. Filter group rx, stock, staff. 3. Page with `beforeSeq`. 4. Call with `limit=201` and `beforeSeq=0`.	Only this pharmacy's entries appear, newest first. Entries from PA-003 to PA-043 are present with correct action names. `limit=201` or `beforeSeq=0` gives 400.	No one
PA-046	Profile opening hours	1. Open the Profile section. 2. Change opening hours and save. 3. Send `PATCH .../profile` with `{"openingHours":{}}`.	2: saved, audit `staff.profile_hours`. 3: 400 with `Nothing to change`.	No one (audit entry only)
PA-047	RBAC: other roles denied	1. As PHARMACIST, DOCTOR, HOSPITAL_ADMIN and CITIZEN call `GET /api/v1/pharmacy-admin/overview`.	403 for every role except PHARMACY_ADMIN. The web route `/pharmacy-admin` shows the AccessDenied screen for a wrong role.	No one

ID	Scenario	Steps	Expected result	Who is notified
PA-048	Pharmacy admin does not notify	1. Keep a second tab as PHARMACIST (Joseph Mathew) and a third as DOCTOR. 2. As Suma, hide a batch, confirm a recall and send back a PO. 3. Watch both tabs for 30 seconds.	No toast and no new feed item appears in the other tabs.	No one

---

HOSPITAL-ADMIN

Persona: Dr. Meera Krishnan (HOSPITAL_ADMIN), screen `/hospital-admin` with sections overview, approvals, staff, admissions, roster, beds, roles, profile, complaints, reviews, breakglass (Break-glass reviews), audit. Every action is limited to the admin's hospital and writes a hospital-scoped audit entry. Only citizen-originated and doctor-originated events reach this admin (complaint, review, booking, referral, break-glass); the admin's own actions emit no events.

ID	Scenario	Steps	Expected result	Who is notified
HA-001	Overview loads	1. Sign in as Dr. Meera Krishnan. 2. Open `/hospital-admin?section=overview`.	KPI tiles (pending approvals, break-glass reviews due, bed occupancy), recent activity and the live event feed load. No error.	No one
HA-002	Approvals list and counts	1. Open Approvals. 2. Switch filters pending, doctors, decided, all. 3. Call `GET .../approvals?filter=other`.	Counts (pending, doctors, decided, total) match the lists. Only `hospital_staff` requests for this hospital appear. Bad filter: 400.	No one
HA-003	Approve blocked until every document is checked	1. Open a pending applicant that has unchecked documents. 2. Click Approve without checking them.	Approve is disabled, or the call returns 409 `Mark every document as checked before approving (N left).`	No one
HA-004	Check documents then approve	1. Tick each document of the applicant (API: `POST .../approvals/:id/documents/:index/check` with `{"checked":true}`). 2. Click Approve (optional reason).	Message "`<name>` can now sign in to the Staff Portal. They were told by SMS and email (mock)." Request becomes approved and the account becomes active. Audit `admin.approve`. No SMS or email is sent.	No one (audit entry only)
HA-005	Expired registration blocks approval	1. Find an applicant whose registration document is marked expired (seed; tester to confirm one exists). 2. Try to approve.	409 with `Registration expired. <title> (<meta>). Approving is blocked until a renewed certificate is uploaded.` Even with all boxes ticked.	No one

ID	Scenario	Steps	Expected result	Who is notified
HA-006	Document index out of range	1. Call `POST .../approvals/<id>/documents/99/check` with `{"checked":true}`.	404 `Document not found.`	No one
HA-007	Reject with reason code	1. Open a pending applicant. 2. Reject with code `registration_unverified`.	Request becomes rejected, account status `rejected` with reason text. Audit `admin.reject`.	No one (audit entry only)
HA-008	Reject with `other` needs a note	1. Reject with code `other` and no note. 2. Repeat with a note "Wrong hospital".	1: 400 `Please write the reason.` 2: succeeds; stored reason is "Other: Wrong hospital" style (label then note).	No one (audit entry only)
HA-009	Reason codes list	1. Open the reject dialog, or read `rejectReasons` in the approvals response.	Exactly 5 codes: registration_unverified, registration_expired, document_unreadable, not_employed_here, other. An unknown code gives 400.	No one
HA-010	Decide twice	1. Approve an applicant, then call approve or reject again, or tick a document.	409 `This applicant has already been decided.`	No one
HA-011	Applicant of another hospital	1. Take an approval id belonging to another hospital (ask Athun). 2. Call `GET .../approvals/<id>`.	404 `Applicant not found in your hospital.`	No one
HA-012	Staff list filters	1. Open Staff. 2. Filter by role doctor, nurse, lab, radiology, pharmacist. 3. Search by name.	Only staff of this hospital with the chosen role. `limit` above 200 gives 400.	No one
HA-013	Create staff	1. Staff > Add (API `POST .../staff`) with a valid `personId`, `staffRole` nurse, and a department of this hospital.	Account created as `active` at once (no activation link). Audit entry. Repeat with `staffRole` "doctor": 400 (only nurse, lab, radiology). Wrong hospital or department: error (tester to confirm text).	No one (audit entry only)
HA-014	Permissions matrix view	1. Open Roles (permissions). 2. Look at roles doctor, nurse, lab, radiology, pharmacist, front_desk.	A grid of permissions per role. Rows marked as national rules show locked. Hospital overrides show as the effective value.	No one
HA-015	Change an allowed permission	1. Toggle one unlocked permission for the nurse role and save. 2. Reload.	Change persists as a hospital override. Audit `admin.permission`. Restore the original value.	No one (audit entry only)
HA-016	Unknown permission or wrong pair	1. Call `PUT .../permissions` with `permissionCode: "nope"`. 2. Call with a real code that does not belong to the role.	1: 400 `Unknown permission "nope".` 2: 400 `This role and permission pair does not exist.` Nothing is saved (single transaction).	No one

ID	Scenario	Steps	Expected result	Who is notified
HA-017	National rule cannot be overridden	1. Pick a locked (national) permission. 2. Try to change it for any role via `PUT .../permissions`.	403 `This permission is a national rule and cannot be changed by a hospital.`	No one
HA-018	Permissions payload limits	1. Send `changes: []`. 2. Send 61 changes. 3. Send `roleKey: "admin"`.	All three 400 `Invalid request` (1 to 60 changes; role keys fixed).	No one
HA-019	Departments: create and rename	1. Departments (staff screen) > Add "Test Dept QA". 2. Rename to "Test Dept QA 2". 3. Deactivate it.	Each saves. Audit `department.created` and `department.updated`. Name length 2 to 80.	No one (audit entry only)
HA-020	Departments: duplicate name	1. Create "Test Dept QA" again (any letter case).	409 `A department with this name already exists.` Same on renaming to an existing name.	No one
HA-021	Department of another hospital	1. Call `PATCH .../departments/<id of other hospital>` with a name.	404 `Department not found in your hospital.` Empty body gives 400 `Nothing to change`.	No one
HA-022	Beds: all five statuses	1. Open Beds. 2. Filter by ward and department. 3. Look for beds in free, occupied, reserved, cleaning, out_of_service.	All five statuses are present or reachable. Occupied beds show a short patient name.	No one
HA-023	Change a free bed	1. Set a free bed to reserved, then cleaning, then out_of_service, then free.	Each change saves. Audit `bed.status` ("Bed set to ..."). District bed counts follow.	No one (audit entry only)
HA-024	Change an occupied bed	1. Pick an occupied bed (seed: Ward 3, Bed 7, Thomas Kurian). 2. Try to set it to cleaning.	409 `This bed has a patient. Discharge or move the patient first.` Setting status `occupied` through the API gives 400 (not an allowed value).	No one
HA-025	Bed of another hospital	1. Call `PATCH .../beds/<other hospital bed id>` with `{"status":"free"}`.	404 `Bed not found in your hospital.`	No one
HA-026	Admissions list	1. Open Admissions. 2. Filter by department.	Current inpatients of this hospital with department. `limit` up to 200.	No one
HA-027	Roster: view and edit	1. Open Roster for the current week (Monday start). 2. Change one doctor cell to shift `night` and save. 3. Reload.	Cell persists. Shifts allowed: op, night, off, ward_round, teleconsult. Audit `roster.updated`.	No one (audit entry only)

ID	Scenario	Steps	Expected result	Who is notified
HA-028	Roster: week must start on Monday	1. Call `GET .../roster?weekStart=2026-10-18` (a Sunday). 2. Call `PUT .../roster` with that weekStart. 3. Call `POST .../roster/publish` with it.	Each: 400 `weekStart must be a Monday (YYYY-MM-DD).` A Monday date such as 2026-10-19 works.	No one
HA-029	Roster: date outside week, foreign doctor	1. `PUT .../roster` with weekStart 2026-10-19 and a cell dated 2026-10-27. 2. `PUT` with a doctor user id from another hospital.	1: 400 `Every date must be inside the chosen week.` 2: 400 `One or more doctors do not work at your hospital.`	No one
HA-030	Roster: publish	1. Edit the roster, then click Publish for that week.	Success. Audit `roster.published`. Tester to confirm whether doctors see the published roster. No event is emitted.	No one (audit entry only)
HA-031	Break-glass list and status	1. Open Break-glass reviews. 2. Compare statuses review_due, justified, escalated.	Each case shows doctor, patient (short name, or the temporary label for an unidentified person), reason category, reason text, hours left (72-hour window) and the district status. "Need review" count matches the top tile.	No one
HA-032	Justify a break-glass case	1. Open a `review_due` case. 2. Click Justify with an optional note.	Status `justified`. Audit `breakglass.justified`. A second review of the same case is refused (one review per case).	No one (audit entry only)
HA-033	Escalate a break-glass case	1. Open another `review_due` case. 2. Click Escalate with note "No clinical reason found".	Status `escalated`. A flagged event (rule `break_glass_not_justified`, severity high, level district) is created for the district admin. Audit `breakglass.escalated`.	Ajay Kumar (DISTRICT_ADMIN) sees a flagged audit event in the Audit section; no `engage.event` is sent
HA-034	Escalate needs a reason, review twice	1. Escalate with note "abc" (3 characters). 2. Justify or escalate an already reviewed case.	1: 400 (note min 5 characters, `Say why this was not justified`). 2: 409 with the database message (already reviewed or window closed; tester to confirm exact words).	No one
HA-035	Break-glass of another hospital	1. Take a break-glass session id from another hospital (ask Athun). 2. Call `POST .../break-glass/<id>/justify`.	403 `This emergency access is not in your hospital.` A hospital admin with a visiting posting at the doctor's hospital may review (seeded visiting-posting case; tester to confirm).	No one
HA-036	Audit log scope	1. Open Audit. 2. Filter groups access, admin, system. 3. Compare with another hospital's admin (ask Athun for a second hospital admin or use DB).	Only this hospital's entries. Entries from HA-004 to HA-033 appear. `limit` above 200 gives 400.	No one
HA-037	Complaints list and timeline	1. Open Complaints. 2. Filter statuses new, under_review, resolved, escalated, open. 3. Open a complaint timeline.	Complaints of this hospital with reference `CMP-NNNN` and a 7-day reply deadline. Timeline events are in order and cannot be edited.	No one

ID	Scenario	Steps	Expected result	Who is notified
HA-038	Assign a new complaint	1. Open a new complaint (status open). 2. Assign to a staff member of this hospital with a note.	Status becomes assigned (shown as under_review). Note added to the timeline. Audit `complaint.assigned`.	No one (audit entry only)
HA-039	Assign: wrong state and wrong person	1. Assign the same complaint again. 2. Assign another new complaint to a person of a different hospital.	1: 409 `Only a new complaint can be assigned.` 2: 404 `That person does not work at your hospital.` A reopened complaint can be assigned again.	No one
HA-040	Resolve a complaint	1. Resolve an open or assigned complaint with resolution text of 5 or more characters. 2. Open the citizen's Complaints screen as Anjali (if it is her complaint).	Status `resolved`. Timeline adds "Citizen notified of the resolution (mock SMS and app message)". Audit `complaint.resolved`. The citizen does not get a toast (no event is emitted); the citizen sees the change on the Complaints screen.	No one (audit entry only)
HA-041	Resolve: invalid	1. Resolve with text "abc". 2. Resolve an already resolved complaint. 3. Resolve a complaint of another hospital.	1: 400 `Invalid request`. 2: 409 `This complaint cannot be resolved from the hospital any more.` 3: 404 `Complaint not found in your hospital.`	No one
HA-042	Reviews and reply	1. Open Reviews, filter by 1 to 5 stars. 2. Reply to one with text of 2 to 1000 characters.	Reply saved, audit `review.reply`. Reply visible to the citizen on their Reviews screen. Reply to another hospital's review: 404 `Review not found for your hospital.`	No one (audit entry only)
HA-043	Profile change request	1. Open Profile. 2. Submit a change (phone, address, timings, services, show in Find care, accepts bookings). 3. Submit again before the district decides.	2: accepted, audit `hospital.profile_change_requested`, goes to district approval. 3: 409 `A profile change is already waiting for district approval.` An empty change gives 400 `Nothing to change`. Approving it does not yet update the hospital row (known gap).	No one (audit entry only)
HA-044	RBAC and wrong-role access	1. Call `GET /api/v1/hospital-admin/overview` as DOCTOR, PHARMACY_ADMIN, DISTRICT_ADMIN and CITIZEN. 2. Open `/hospital-admin` in the web app signed in as a NURSE.	API: 403 for all. Web: AccessDenied screen.	No one
HA-045	Hospital admin events received	1. Keep Dr. Meera in one tab. 2. In other tabs: as Anjali file a complaint and post a review; as Dr. Arun Nair create a referral and use break-glass (see NOTIF rows). 3. Watch Dr. Meera's tab.	Toasts and feed items for complaint, review, referral, break-glass (and booking when Anjali books at this hospital). Not for actions taken by Dr. Meera herself.	Dr. Meera Krishnan (HOSPITAL_ADMIN) for each, by event type

GOV-CONSOLE

Four roles share one console (`GovConsole`): DISTRICT_ADMIN at `/district-admin`, STATE_ADMIN at `/state-admin`, ZONAL_ADMIN at `/zonal-admin`, CENTRAL_ADMIN at `/central-admin`. Sections: overview, map, approvals, inbox, alerts, surveillance, blood, audit, logs, reports, directory, admins. Central only: ai (AI governance) and settings (System settings). The API is `/api/v1/gov/*`. The level and the area always come from the signed-in admin's current admin post; no request parameter can widen them. Data outside the area is refused with 403 where an id is supplied. Counts below the small-cell limit (default 5) are hidden and shown as `<5`.

The demo-only "peer stand-in": a checkbox in the web console (`asPeer` in the API, label like "Demo only: a peer admin signs as an additional approver") lets another admin of the same level and area act as the second signer. The response then has `simulatedSecondSigner: true` and an audit entry is written. If no such peer exists the call returns a 409.

Approval rules by subject (`admin.approval_rule`)

Subject (what is being approved)	Steps and approver level	Escalates to if overdue or escalated by hand	Special
doctor (public doctor registration)	Step 1 district admin, step 2 state admin	state, then zonal	7 days per step; assigned to the district admin, not the hospital admin
flagged_doctor	Central admin	nobody (409 on escalate)	
hospital_admin (registration)	District admin	state	
pharmacy_admin (registration)	District admin	state	
hospital	District admin	state	
pharmacy	District admin	state	
flagged_citizen	Step 1 district, step 2 state	state, then zonal	
district_admin (created by a state admin)	Zonal admin	central	
state_admin (created by a zonal admin)	Central admin	nobody	
zonal_admin (created by a central admin)	Central admin	nobody	Needs two persons (two different central admins)
hospital_staff (nurse, lab, radiology, doctor joining a hospital)	Hospital admin (hospital console)	district	One step; seeded

Two paths exist for the same inbox:

- New path `/api/v1/gov/approvals/*` (used by the console): scoped by area, enforces the two-person rule, supports more-info and escalate.
- Legacy path `/api/v1/admin/approvals` (GET inbox, `:id/approve`, `:id/reject`): returns every open request of the admin's level (no area filter) and does not enforce the two-person rule.

ID	Scenario	Steps	Expected result	Who is notified
GOV-001	Context and scope per level	1. Sign in as each of Ajay Kumar, Latha Nair, R. Venkatesh, S. Banerjee in turn. 2. Open `/gov/context` data (header of the console, or `GET /api/v1/gov/context`).	Each shows own level and area: district "Pathanamthitta", state "Kerala", zone "South zone", national "India". Labels for child units differ (districts, states, States/UTs).	No one
GOV-002	Level cannot be widened by a parameter	1. As DISTRICT_ADMIN call `GET /api/v1/gov/overview?districtId=<another district>&stateId=1&level=central`. 2. Compare with the normal overview.	Extra parameters are ignored. Data covers only Pathanamthitta.	No one
GOV-003	Overview and map by level	1. As each of the four admins open Overview and Map. 2. Switch the map metric (registered, disease, blood) and disease.	District: only own district. State: districts of Kerala. Zonal: states of the South zone. Central: all states. Counts under the small-cell limit show `<5`. Invalid metric gives 400.	No one
GOV-004	Approvals inbox and list filters	1. Open Approvals and Inbox. 2. Filter all, waiting, decided. 3. Call `GET .../approvals?status=open`.	Waiting items are first, urgent first, soonest due first. Escalated originals are hidden (their live copy shows one level up). Invalid status: 400.	No one
GOV-005	Approve a one-step request	1. As DISTRICT_ADMIN open a pending `hospital_admin` (or `pharmacy_admin`) request. 2. Approve with an optional reason.	Success with `nextStep: false`, `accountActivated: true`. Request status approved, account active. Audit `approval.approved`.	No one (audit entry only)
GOV-006	Two-step request (doctor)	1. As DISTRICT_ADMIN approve a pending `doctor` request (step 1). 2. Check the account status. 3. Sign in as STATE_ADMIN and find the step-2 request. 4. Approve it.	Step 1: `nextStep: true`, account still pending, new request appears in the state inbox. Step 2: `accountActivated: true`.	No one (audit entry only)
GOV-007	Reject needs a reason	1. Reject a pending request with an empty reason. 2. Reject with reason "HPR number does not match". 3. Check the account.	1: 400 `Invalid request` with issue `A reason is required` (UI blocks it). 2: success, request rejected, account `rejected` with the reason stored. Audit `approval.rejected`.	No one (audit entry only)
GOV-008	Ask for more information and resume	1. On a pending request choose More info and enter "Please send the council certificate". 2. Reload and check the status. 3. Approve the same request.	Status `more_info`, note shown with the time. Approving a `more_info` request resumes it and decides it. Audit `approval.more_info`. A request already in `more_info` cannot be sent for more info again: 409 `This request has already been decided or escalated.` Empty note: 400 `Say what is missing`.	No one (audit entry only)

ID	Scenario	Steps	Expected result	Who is notified
GOV-009	Escalate by hand	1. As DISTRICT_ADMIN escalate a pending `hospital` request with a reason. 2. Sign in as STATE_ADMIN and look in the inbox.	Success with `escalatedToLevel: state` and a `newRequestId`. The original becomes `escalated` and is hidden from lists. A fresh request with a new time limit sits with the state admin. Audit `approval.escalated`.	No one (audit entry only)
GOV-010	Escalate a request that cannot go higher	1. As CENTRAL_ADMIN open a `state_admin` or `flagged_doctor` request. 2. Click Escalate.	409 `This kind of request cannot be escalated any higher.`	No one
GOV-011	Wrong level or area	1. As DISTRICT_ADMIN take the id of a request assigned to the state level (copy it from the STATE_ADMIN network tab). 2. Call approve, reject, more-info and escalate on it.	Each: 403 `This request is not assigned to your level and area.` Nothing changes.	No one
GOV-012	Unknown, bad and already decided ids	1. Approve a random valid UUID. 2. Approve id "abc". 3. Approve a request that is already approved.	1: 404 `Approval request not found.` 2: 400 `Invalid request`. 3: 409 `This request has already been decided or escalated.`	No one
GOV-013	Two-person rule: first signature	1. As CENTRAL_ADMIN (S. Banerjee) open a pending `zonal_admin` request. 2. Approve once (no stand-in).	`nextStep: false`, `accountActivated: false`, `twoPerson.state: "waiting_second_signature"` with the first signer name. The request stays open (pending). Audit `approval.first_signature`.	No one (audit entry only)
GOV-014	Two-person rule: same admin signs twice	1. Approve the same request again as S. Banerjee without the stand-in checkbox.	409 `A different admin must give the second signature. You gave the first one.`	No one
GOV-015	Two-person rule: demo peer stand-in	1. Approve again with the "Demo only: a peer admin signs" checkbox on (API `asPeer: true`). 2. Repeat on another `zonal_admin` request on a level with no peer.	1: success, `twoPerson.state: "complete"`, `simulatedSecondSigner: true`, account active, audit `approval.second_signature_simulated`. 2: 409 `No other admin of your level and area exists to act as second signer.` Tester to confirm whether a second central admin is seeded.	No one (audit entry only)
GOV-016	Two-person rule by a different real admin	1. After a first signature by S. Banerjee, ask Athun for a second central admin account, or use DB to simulate. 2. Approve as that second admin.	Request completes without `simulatedSecondSigner`. Tester to confirm: the demo sign-in cannot reach a second central admin.	No one (audit entry only)
GOV-017	Legacy path: no area filter	1. As DISTRICT_ADMIN call `GET /api/v1/admin/approvals`. 2. Call `GET /api/v1/gov/approvals/inbox`.	Legacy returns all open requests of the district level (even other districts); the new path returns only those of the admin's area. Record both counts.	No one

ID	Scenario	Steps	Expected result	Who is notified
GOV-018	Legacy path: no two-person enforcement	1. As CENTRAL_ADMIN call `POST /api/v1/admin/approvals/<zonal_admin request id>/approve` once (use a fresh request). 2. Check the account status.	Per code and the session notes the legacy path does not enforce the two-person rule, so one call may activate the account. Record the real result (this is a known discrepancy).	No one (audit entry only)
GOV-019	Legacy path: reject needs reason	1. Call `POST /api/v1/admin/approvals/<id>/reject` with `{}`. 2. Call it as a CITIZEN.	1: 400 (reason required). 2: 403.	No one
GOV-020	Overdue escalation job: secret handling	1. Call `POST /api/v1/admin/approvals/escalate` with no `x-cron-secret` header. 2. Call it with header `x-cron-secret: wrong`. 3. Ask Athun to call it with the real secret.	1 and 2: 403 `Not allowed.` (the route needs no sign-in but needs the secret). If `CRON_SECRET` is unset the route is closed to everyone. 3: `{ "success": true, "escalated": N }`; each overdue request is copied one level up, original `escalated`, audit `approval.escalated` by the system. No scheduler is configured, so nothing runs by itself.	No one (audit entry only)
GOV-021	Create a health alert as draft	1. As DISTRICT_ADMIN open Alerts > New. 2. Pick target district Pathanamthitta, category, title, body, severity normal. 3. Choose Save as draft.	Status `draft`, no reach count yet. Audit `alert.create`. Citizens do not see it.	No one (audit entry only)
GOV-022	Send a draft	1. Open the draft from GOV-021 and click Send.	Status `sent`, `sent_at` set, reach count equals active citizen accounts in the area (muted categories excluded unless emergency). Audit `alert.broadcast`. Anjali sees it in `/citizen/alerts`.	Citizens whose profile district falls in the target, as health alerts in their Alerts screen (not as `engage.event` toasts). Anjali Menon sees it.
GOV-023	Send a non-draft	1. Call `POST .../alerts/<sent alert id>/send`.	409 `Only a draft can be sent from here.`	No one
GOV-024	Send a normal alert immediately	1. New alert, severity normal, not draft, no schedule.	Status `sent` at once with a reach count. Audit `alert.broadcast`.	Citizens in the target area (Alerts screen)
GOV-025	Schedule an alert	1. New alert with a scheduled time well in the future. 2. Check status.	Status `scheduled`. The code compares with the real clock, not DEMO_NOW. Tester to confirm: does it ever become `sent` by itself (no scheduler found)? A bad time gives 400 `Invalid scheduled time.`	No one until sent
GOV-026	Emergency alert needs a second approver	1. As STATE_ADMIN create an alert of type emergency (not draft). 2. Check status and what Anjali sees.	Status `pending_second_approval`. It is not sent. Citizens see nothing yet. Audit `alert.create`.	No one yet

ID	Scenario	Steps	Expected result	Who is notified
GOV-027	Second approval by the issuer	1. Open the pending emergency alert as the issuer. 2. Click Approve without the stand-in.	409 `A different admin must approve an emergency alert. You issued this one.`	No one
GOV-028	Second approval with demo peer	1. Click Approve with the stand-in checkbox (`asPeer`). 2. Repeat on a level that has no peer admin.	1: status `sent` (or `scheduled` if a future time was set), reach count set, `simulatedSecondSigner: true`, audit `alert.second_approval`. 2: 409 `No other admin of your level and area exists to act as second approver.`	Citizens in the target area (Alerts screen, emergency group) after step 1
GOV-029	Second approval in wrong state	1. Call `POST .../alerts/<sent alert>/second-approve`.	409 `This alert is not waiting for a second approval.`	No one
GOV-030	Cancel rules	1. Cancel a draft. 2. Cancel a pending emergency alert. 3. Cancel a scheduled alert. 4. Cancel a sent alert. 5. Cancel an already cancelled alert.	1 to 3: status `cancelled`, audit `alert.cancel`. 4: 409 `A sent alert cannot be cancelled.` 5: also 409 with the same words (cancelled is not in the allowed list; note the wording).	No one (audit entry only)
GOV-031	Alert target scope	1. As DISTRICT_ADMIN create alerts with target national, then state Kerala, then another district. 2. As STATE_ADMIN target a district of another state, then national. 3. As ZONAL_ADMIN target another zone. 4. As CENTRAL_ADMIN target national. 5. Create one with no target id.	Refused cases: 403 `That target is outside your area.` Missing id: 400 `A target id is required.` Central national alert: allowed. District admin may target only own district; state admin own state or its districts.	No one on refusal
GOV-032	Alert of another area	1. As CENTRAL_ADMIN create a national alert as a draft and copy its id. 2. As STATE_ADMIN call send and cancel on that id (a national alert is outside a state admin's area).	403 `That alert is outside your area.` Unknown id: 404 `Alert not found.`	No one
GOV-033	Reach count	1. Use the Reach preview (`POST .../alerts/reach`) for district, state, zone and national targets. 2. Compare with the count after sending.	Preview number equals the stored `reach_count` for the same target and category. Counts only active citizen accounts (phone-only people are not counted, there is no phone registry).	No one

ID	Scenario	Steps	Expected result	Who is notified
GOV-034	Who in the citizen app sees an alert	1. Send a national alert, a Kerala alert, and a Pathanamthitta alert. 2. Open `/citizen/alerts` as Anjali (Pathanamthitta, Kerala, South zone). 3. Ask Athun for a citizen of another district and check.	Anjali sees all three. A citizen of another district sees the national alert, and the state alert only if in that state, and not the Pathanamthitta alert. Emergency alerts show under the emergency group.	Citizens by area, not government roles
GOV-035	Surveillance view and anomaly review	1. Open Surveillance for a disease. 2. Review an anomaly as `reviewed`, then another as `dismissed`. 3. Call review with status "ignored".	Anomalies are scoped to the admin's area. Valid statuses: reviewed, dismissed. "ignored": 400. An anomaly outside the area: 403 `That anomaly is outside your area.` Audit `surveillance.anomaly_review`.	No one (audit entry only)
GOV-036	Response actions	1. Create an action for a known disease with a title (status defaults to planned). 2. Move it to in_progress, then done. 3. Try disease "xyz", status "closed", and an action of another level.	Valid transitions work, audit `surveillance.action_create` and `surveillance.action_update`. Unknown disease: 404 `Unknown disease.` Bad status: 400. Other level or area: 404 `Response action not found in your area.`	No one (audit entry only)
GOV-037	Field investigation requests	1. On an anomaly request a field investigation for team "Rapid Response Team A". 2. Request the same team again. 3. Request another team.	1: created (requested). 2: 409 `A field investigation for this team is already open.` 3: created. Anomaly outside area: 403. Audit `surveillance.field_request`.	No one (audit entry only)
GOV-038	Blood: view and notify donors	1. Open Blood. 2. On an open blood request in the area click Notify matching donors. 3. Repeat for a request in another district and for a fulfilled one.	2: response `matchingDonors: N`, channel "Citizen app", `simulated: true`. Audit `blood.notify_donors`. No citizen receives anything (simulated). 3: 403 `That request is outside your area.` / 404 `Open blood request not found.`	No one (audit entry only)
GOV-039	Directory	1. Open Directory. 2. Switch kind doctors, facilities, staff and status all, active, pending, suspended. 3. Search by name; try `kind=nurses` and `limit=201`.	Lists are limited to the admin's area. Invalid kind or limit gives 400.	No one
GOV-040	Admins and grievances lists	1. Open Admins and Grievances sections.	Admins of the same and lower level in the area; grievances of the area only. Scope differs by level.	No one
GOV-041	Flagged audit event: justify	1. Open Audit and the flagged events list. 2. Justify an open event with a note.	Status `justified`. Audit `audit.flag_justified`.	No one (audit entry only)
GOV-042	Flagged audit event: escalate	1. Escalate an open event as DISTRICT_ADMIN, STATE_ADMIN, ZONAL_ADMIN with a note. 2. Escalate as CENTRAL_ADMIN.	1: status `escalated` with the next level as target. 2: 409 `There is no higher admin level. Central admins pass flagged events to the National Health Authority security cell outside this system.`	No one (audit entry only)

ID	Scenario	Steps	Expected result	Who is notified
GOV-043	Flagged event: state and area errors	1. Justify an event already reviewed. 2. Justify an event in another district. 3. Use a random id.	1: 409 `This event has already been reviewed.` 2: 403 `That event is outside your area.` 3: 404 `Flagged event not found.`	No one
GOV-044	Logs view	1. Open Logs. 2. Filter all, access, breakglass, admin, export, signin.	Entries are scoped to the area and show non-identifying copies for patient-related entries. Your own GOV actions appear.	No one
GOV-045	Reports list and formats	1. Open Reports. 2. Read the report list, periods, and formats.	Reports available differ by level. CSV available, PDF marked not available. Retention note says 30 days and counts under the limit are hidden.	No one
GOV-046	Create a CSV export (de-identified)	1. Choose a report and a period, format CSV, click Export. 2. Open the CSV.	`content` is CSV, export is marked de-identified, small counts shown as `<5`. No names, no ABHA, no phone, no Aadhaar. Appears in recent exports (max 20). Audit `report.export`.	No one (audit entry only)
GOV-047	PDF export and unknown report	1. Call `POST .../reports/exports` with format `pdf`. 2. Call with a report code the level does not offer.	1: 400 `PDF export is not available in the alpha. Use CSV.` 2: 404 `Unknown report for your level.`	No one
GOV-048	Download and expiry	1. Download your own export. 2. Copy its id; call download as an admin of another area. 3. Ask Athun to set an export's age to over 30 days in the DB, then download.	1: file with the same name, audit `report.download`; numbers may differ because data is live. 2 and 3: 404 `Export not found, expired, or outside your area.`	No one (audit entry only)
GOV-049	System settings: flags view (central)	1. As CENTRAL_ADMIN open Settings. 2. Read flags, history, rules, health checks.	Five platform flags (include `bg`, `ai`, `maint`) with values, an immutable history list, rules, health checks (migrations applied, audit streams). Footnote: emergency access never turns off with maintenance.	No one
GOV-050	Flag change: same value and unknown flag	1. Set `bg` to enabled while it is already enabled. 2. Set flag code "zzz".	1: 409 `The flag already has that value.` 2: 404 `Unknown platform flag.` Reason is required (max length per schema).	No one
GOV-051	Flag change needing two central admins	1. Request to turn `bg` OFF with a reason. 2. Confirm as the same admin without the stand-in. 3. Confirm with the stand-in.	1: `applied: false`, `pending: true`, audit `platform.flag_requested`. 2: 409 `A different central admin must confirm this change. You requested it.` 3: `applied: true`, `simulatedSecondSigner: true`, audit `platform.flag_changed`; a pending request older than 72 hours is ignored. No other central admin: 409 `No other central admin exists to act as second signer.` High-impact means: maintenance ON, break-glass OFF, AI OFF. Turning them back ON applies at once.	No one (audit entry only)
GOV-052	Flag effect: break-glass off	1. With `bg` OFF (from GOV-051) sign in as Dr. Arun Nair. 2. Open Emergency. 3. Try the break-glass call. 4. Turn `bg` ON again as CENTRAL_ADMIN.	2: banner "Emergency access is switched off". 3: 403 containing `switched off by the platform administrator`. 4: applies at once; break-glass works again. Always restore.	No one (audit entry only)

ID	Scenario	Steps	Expected result	Who is notified
GOV-053	Flag effect: AI off	1. Turn `ai` OFF (two-person). 2. As Dr. Arun Nair open an AI tool in a session. 3. Turn `ai` ON again.	2: 503 `AI features are switched off by the platform administrator`. Citizen AI chat behaviour with the flag off: tester to confirm. Always restore.	No one (audit entry only)
GOV-054	Flag effect: maintenance (do not test without Athun)	1. Read the description of `maint`. 2. Only with Athun's agreement request and confirm maintenance ON, observe, then turn it OFF.	Effect on citizens and staff: tester to confirm. Emergency access must stay available during maintenance. Restore immediately.	No one (audit entry only)
GOV-055	Flag history is permanent	1. After GOV-051 to GOV-053 read the flag history. 2. Try to edit or delete a history row via the API.	History lists every change with who and when. There is no edit or delete route; the database rejects changes (rule test).	No one
GOV-056	AI governance overview	1. Open the AI section. 2. Read model versions, release requests, safety reports.	Version states shown from: pending, shadow, live, on_hold, rolled_back, retired. Every item marked simulated. Drift above the rollback limit shows a danger tone.	No one
GOV-057	Release sign-off: two different sign-offs	1. On a `waiting` release request choose Approve (first sign-off). 2. Approve again as the same admin without the stand-in. 3. Approve again with the stand-in checkbox.	1: `approvals: 1`, `required: 2`, status stays waiting. 2: 409 `You have already signed this request. A different approver is needed.` 3: `approvals: 2`, status `approved`, `simulatedSecondSigner: true`. No other central admin: 409 `No other central admin is left to sign.` Audit `ai.release_signoff`.	No one (audit entry only)
GOV-058	Release hold	1. On a waiting request choose Hold without a reason. 2. Hold with reason "Needs more shadow-run days". 3. Try to sign the held request.	1: 400 `A reason is required to put a release on hold.` 2: status `on_hold`. 3: 409 `This request is already on hold.`	No one (audit entry only)
GOV-059	Release go-live	1. Try Release on a `waiting` request. 2. Release an `approved` one. 3. Look at the model's older live version.	1: 409 `Only an approved release request can go live.` 2: status `released`, new version `live` with release time, audit `ai.release`. 3: previous live version of the same model is `retired`. Unknown id: 404 `Release request not found.`	No one (audit entry only)
GOV-060	Drift rule	1. Find a live version with drift 3% and one with drift 6% in the register (seeded). 2. Compare status and tone.	3% stays `live`. 6% is `rolled_back` (automatic rule, covered by the database rule tests). Tester to confirm the seeded values and the rollback limit shown (code default 5%, database rule value).	No one
GOV-061	Safety reports	1. Change a safety report to `reviewing`, then `closed`. 2. Send status "done". 3. Use a random id.	1: success, closed time set on `closed`, audit `ai.safety_report_update`. 2: 400. 3: 404 `Safety report not found.`	No one (audit entry only)

ID	Scenario	Steps	Expected result	Who is notified
GOV-062	RBAC: central-only endpoints	1. As DISTRICT_ADMIN, STATE_ADMIN and ZONAL_ADMIN call `GET /api/v1/gov/system`, `GET /api/v1/gov/ai`, `POST /api/v1/gov/system/flags/bg`, `POST /api/v1/gov/ai/release-requests/<id>/signoff`. 2. Open `/district-admin?section=ai` and `?section=settings`.	API: 403 for each. Web: the AI and Settings tabs are not shown to non-central roles (tester to confirm what a direct section URL shows).	No one
GOV-063	RBAC: non-government roles	1. As CITIZEN, DOCTOR, HOSPITAL_ADMIN and PHARMACY_ADMIN call `GET /api/v1/gov/overview` and `GET /api/v1/admin/approvals`.	403 for every role.	No one
GOV-064	RBAC: admin creation endpoints	1. As DISTRICT_ADMIN call `POST /api/v1/admin/create-admin`. 2. As STATE_ADMIN call `GET /api/v1/admin/zones` and `GET /api/v1/admin/states`. 3. As ZONAL_ADMIN call `GET /api/v1/admin/zones`, `GET /api/v1/admin/states`, `POST .../create-admin`.	1: 403. STATE_ADMIN: zones 403, states 403. ZONAL_ADMIN: zones 403, states 200, create-admin 200 only with valid body (creates a state admin; wrong creator role gives 403).	No one
GOV-065	Government actions send no events	1. Keep tabs open for Anjali (CITIZEN), Dr. Arun Nair, Dr. Meera Krishnan. 2. As gov admins approve, reject, escalate, ask more info, justify a flag, export a report. 3. Watch the other tabs 30 seconds.	No toast and no new feed item in any tab. Only audit entries are written. Health alerts reach citizens through the Alerts screen, not through the event feed.	No one

---

ADMIN-HIERARCHY

Who approves whom. This follows the `admin.approval_rule` table and the admin-creation endpoints. The hospital admin sits below the district admin for approvals but is a separate console.

Creates or registers	Created or approved by	Approval step and approver	If overdue (7 days) escalates to
Central admin	Seeded; not created in the app	n/a	n/a

Creates or registers	Created or approved by	Approval step and approver	If overdue (7 days) escalates to
Zonal admin	Central admin (create-admin)	Central admin, two different central admins must sign	nobody
State admin	Zonal admin (create-admin)	Central admin	nobody
District admin	State admin (create-admin)	Zonal admin	central
Hospital admin	Self-registers (`/register/hospital-admin`)	District admin	state
Pharmacy admin	Self-registers (`/register/pharmacy-admin`)	District admin	state
Doctor	Self-registers (`/register/doctor`)	Step 1 district admin, step 2 state admin	state, then zonal
Nurse, lab tech, radiology tech	Hospital admin (create-staff, active at once) or seeded `hospital_staff` request	Hospital admin approves seeded requests	district
Pharmacist	Pharmacy admin (create or invite)	none (active at once)	n/a
Hospital, pharmacy (facility)	Registration	District admin	state
Citizen	Self-registers, active at once	none (flagged citizen: district, then state)	state, then zonal

ID	Scenario	Steps	Expected result	Who is notified
HIER-001	Approval chain for a doctor	1. Register a new doctor at `/register/doctor` using a fresh citizen `personId` and HPR `DEMO-HPR-71-0099`. 2. As DISTRICT_ADMIN find the request and approve. 3. As STATE_ADMIN approve step 2.	Request first appears in the district inbox (not in the hospital admin's Approvals). After step 2 the account is `active` (the new person still cannot sign in; demo login is persona-only). Tester to confirm the doctor request appears for Dr. Meera Krishnan: expected no.	No one (audit entry only)
HIER-002	Hospital admin or pharmacy admin registration	1. Register a hospital admin for an active hospital. 2. As DISTRICT_ADMIN approve.	One step, account `active`. Escalation target is the state admin.	No one (audit entry only)
HIER-003	Create-admin chain	1. As CENTRAL_ADMIN create a zonal admin (zone required). 2. As ZONAL_ADMIN create a state admin (state required). 3. As STATE_ADMIN create a district admin (district required). 4. Omit the zone, state or district in each case.	Each creates a `pending` user, an admin post and an approval request to the right approver. Missing zone, state or district: 400. Wrong creator role: 403.	No one (audit entry only)
HIER-004	Approver cannot approve outside their level	1. Try each approver on one request of every other level (use the gov console API with copied ids).	Always 403 `This request is not assigned to your level and area.` Higher levels do not see lower-level requests unless escalated.	No one

ID	Scenario	Steps	Expected result	Who is notified
HIER-005	Escalation climbs one level	1. Escalate a `doctor` request by hand at district, then at state, then at zonal.	district to state to zonal. At zonal the request still escalates to central only if the rule says so; tester to confirm. For `state_admin` and `zonal_admin` subjects the escalate button gives 409.	No one (audit entry only)

NOTIFICATION-MASTER-MATRIX: who is told what

The only live channel is the in-app event feed. An event is visible only to the roles named (inside the right hospital, pharmacy, district, state or zone), or to the one named person, or to the sender. Nothing is sent by SMS, email or push.

Action / trigger	Performed by	Event type	Who IS notified	Who must NOT be notified	How to verify
Book or cancel appointment	Citizen	`booking`	Doctor and Hospital admin of the slot's hospital	Other hospitals, government admins	Doctor tab and Hospital admin tab
End a doctor's session	Citizen	`session-ended`	That doctor only	Other doctors	Doctor tab toast
Share AI chat	Citizen	`ai-chat-shared`	That doctor only	Others	Doctor tab
Home reading beyond hard limits	Citizen	`vitals`	Doctor on record	Others, government admins	Doctor tab
Send a message	Citizen	`message`	The doctor, or the hospital	Others	Doctor tab
File or reopen complaint	Citizen	`complaint`	Hospital admin (pharmacy admin if pharmacy only), link `/hospital-admin/complaints`	Government admins	Hospital admin tab
Post a review	Citizen	`review`	Hospital admin or Pharmacy admin	Others	Hospital admin tab
Respond to blood request	Citizen donor	`blood-response`	Doctors of the hospital	Others	Doctor tab
Lab or imaging order	Doctor	`lab-order` / `imaging-order`	Lab techs or Radiology techs of the hospital, and the Citizen	Techs of other hospitals	Lab/Radiology tab
Sign prescription	Doctor	`prescription`	Pharmacist (if a linked pharmacy) and Citizen	Pharmacists of unrelated pharmacies	Pharmacist tab
Create referral	Doctor	`referral`	Citizen, Hospital admin, plus the receiving doctor	Other doctors	Each tab
Create handover	Doctor	`handover`	Doctors and nurses of the hospital	Other hospitals	Doctor/Nurse tab
Use break-glass	Doctor	`break-glass`	Hospital admin and the Citizen (title "Emergency access used")	Government admins; citizen text must not show other patients' names	Citizen and Hospital admin tabs
Reply to citizen	Doctor	`message`	The Citizen only	Others	Citizen tab

Action / trigger	Performed by	Event type	Who IS notified	Who must NOT be notified	How to verify
Create blood request	Doctor	`blood-request`	Citizens and the District admin role	Other roles	Citizen tab
Order or sample declined	Lab	`message`	Ordering doctor only	Others	Doctor tab
Critical lab value	Lab	`lab-result` "CRITICAL value"	Ordering doctor only	Others	Doctor tab
Result released	Lab	`lab-result` "Result ready"	Ordering doctor and a separate copy to the Citizen	Doctors at other hospitals	Doctor and Citizen tabs
Order declined	Radiology	`message`	Ordering doctor	Others	Doctor tab
Study reported	Radiology	`imaging-result` "Images ready"	Ordering doctor	Others	Doctor tab
NEWS2 early warning	Nurse	`vitals-critical`	Doctors of the hospital	Others	Doctor tab
Order declined	Nurse	`message`	Ordering doctor	Others	Doctor tab
Pharmacy note	Pharmacist	`message`	Prescribing doctor	Others	Doctor tab
Ready to collect	Pharmacist	`dispensed`	Citizen	Others	Citizen tab
Collected	Pharmacist	`collected`	Citizen	Others	Citizen tab
Handover (lab, nurse, radiology) create / sign	Staff	`handover`	Recipient on create; author on sign (or role-wide)	Others	Recipient tab
Health alert sent	Government admin	health alert feed (not an event)	Active citizens in the scope (national / state / district)	Citizens outside the scope	Citizen Alerts page
Open a record with a key	Doctor	`record_opened` push row (table `engage.notification`)	Patient (row only; nothing in the API shows it)	Everyone else	Known issue 8: check Alerts, Share & access history
Approvals: approve, reject, escalate, more-info	Admins	No event; audit entries	No one	Everyone	Audit log
Registrations (citizen, doctor, admins)	Public	No event; audit entry	No one (approver sees the inbox)	Everyone	Approval inbox
Flagged audit event justify/escalate	Admin	No event; audit entry	No one	Everyone	Audit
Recall confirm, purchase order approval	Pharmacy admin	No event; audit entry	No one	Everyone	Audit

Visibility rules

1. A patient event can never go to district, state, zonal or central admins (database rule).
2. A patient event needs a hospital or pharmacy scope, or a direct recipient, or is citizen-only.
3. The bell counts unread events addressed to me, excluding ones I sent. Read state is per person.

4. A guardian sees a minor's events. A citizen sees only own patient events plus national, own-district, own-state and own-zone broadcasts.
5. Events are immutable (no edit or delete). The `href` must be an in-app path (no scheme, no `//`, no spaces or backslash).
6. Sender role comes from the account: a citizen cannot send as a doctor and can only speak about themselves.

NOTIF: notification test cases

ID	Scenario	Steps	Expected result	Who is notified
NOTIF-001	Toast and bell	1. With Doctor in tab 1, as Citizen in tab 2 book a slot. 2. Watch tab 1 for up to 5 seconds.	Toast appears within about 3 seconds and lasts about 4 seconds; bell count rises by 1.	Doctor + Hospital admin (`booking`)
NOTIF-002	Mark read	1. Open the bell and mark an item read.	Count falls; stays read after reload; other users' read state unchanged.	No one
NOTIF-003	Own events not counted	1. As Doctor reply to a message.	The doctor's own bell does not count their own event.	Citizen
NOTIF-004	Error backoff	1. Go offline for a minute, then back online.	Polling slows (15 s) after an error then returns to 3 s; no duplicate toasts.	No one
NOTIF-005	Cross-role feed	1. As Citizen call `GET /api/v1/events?role=DOCTOR` (copy the exact param from the Network tab).	403.	No one
NOTIF-006	Emit as another role / citizen to staff	1. As Citizen `POST /api/v1/events` with `to:["doctor"]` (or with `hospitalId` / `toUserId`). 2. As Doctor send 11 events within a minute through the same endpoint.	1: 403 "Citizens cannot send notices to staff here. Use messages, bookings or complaints." Role always comes from the account. 2: the 11th gets 429 "Too many notices. Wait a minute and try again."	No one
NOTIF-007	Other hospital isolation	1. Create a lab order at Demo General Hospital. 2. Check a lab tech of another hospital (ask Athun whether one is reachable).	Not visible there.	Only own hospital
NOTIF-008	Government never sees patient events	1. Do citizen/doctor actions. 2. Open District/State/Zonal/Central feeds.	None of them appear.	No one
NOTIF-009	Mark unseen event read	1. Call `POST /events/read` with an id you cannot see.	Refused / not marked.	No one
NOTIF-010	Click-through	1. For each event type in the matrix click the toast or bell item.	Each lands on a valid page (no 404) for that role. Report any link to `/doctor/queue` or `/lab/worklist` (old guessed links).	No one
NOTIF-011	Unread count API	1. Compare `GET /events/unread-count` with the bell.	Same number.	No one
NOTIF-012	Guardian	1. If a guardian with a minor exists, create a minor's event.	Guardian sees it.	Guardian

ID	Scenario	Steps	Expected result	Who is notified
NOTIF-013	Privacy of break-glass text	1. Use break-glass for another patient. 2. Open Anjali's feed.	Anjali sees "Emergency access used" and no other patient's name.	Citizen + Hospital admin
NOTIF-014	Record opened visibility	1. Doctor opens Anjali's record with a key. 2. Check Anjali's Alerts, Share & access, history; turn the preference off.	Record where it appears (if anywhere). Expected by design: "Someone opened my record" alert.	Citizen
NOTIF-015	No SMS/email	1. Check the phone/email of any test persona during a flow.	Nothing is ever sent.	No one

RBAC: who may do what

Allow means the screen or API works. 403 means the API refuses (web shows access-denied). Rows are role groups; "Gov" is district, state, zonal and central admins (area-scoped).

Area	Citizen	Doctor	Nurse	Lab	Radiology	Pharmacist	Pharmacy admin	Hospital admin	Gov (4)	Central only
`/api/v1/citizen/*`	Allow	403	403	403	403	403	403	403	403	403
`/api/v1/doctor/*`	403	Allow	403	403	403	403	403	403	403	403
`/api/v1/nurse/*`	403	403	Allow	403	403	403	403	403	403	403
`/api/v1/lab/*`	403	403	403	Allow	403	403	403	403	403	403
`/api/v1/radiology/*`	403	403	403	403	Allow	403	403	403	403	403
`/api/v1/pharmacist/*`	403	403	403	403	403	Allow	403	403	403	403
`/api/v1/pharmacy-admin/*`	403	403	403	403	403	403	Allow	403	403	403
`/api/v1/hospital-admin/*`	403	403	403	403	403	403	403	Allow	403	403
`/api/v1/gov/*` **(shared)**	403	403	403	403	403	403	403	403	Allow, own area	Allow
`/gov/system`, `/gov/ai/*`	403	403	403	403	403	403	403	403	403	Allow
`/admin/create-admin`	403	403	403	403	403	403	403	403	Central, zonal, state only	Allow
`/admin/create-staff`	403	403	403	403	403	403	403	Allow	403	403
`/admin/create-pharmacist`	403	403	403	403	403	403	Allow	403	403	403
`/auth/me`, `/events`	Allow	Allow	Allow	Allow	Allow	Allow	Allow	Allow	Allow	Allow

Treat "this table" as the expectation from the code. Anything different is a bug (S1 if data of another person is shown, S2 otherwise).

ID	Scenario	Steps	Expected result	Who is notified
RBAC-001	Citizen to doctor API	1. `curl` `/api/v1/doctor/home` with `Bearer demo:CITIZEN`.	403.	No one

ID	Scenario	Steps	Expected result	Who is notified
RBAC-002	Doctor to hospital admin	1. Doctor tab: open `/hospital-admin`; call `/api/v1/hospital-admin/overview` as DOCTOR.	Access-denied; 403.	No one
RBAC-003	Nurse to lab	1. NURSE calls `/api/v1/lab/worklist`.	403.	No one
RBAC-004	District to central-only	1. DISTRICT_ADMIN calls `/api/v1/gov/system` and `/gov/ai`.	403.	No one
RBAC-005	District outside area	1. DISTRICT_ADMIN asks for another district's data.	403 "outside your area".	No one
RBAC-006	Pharmacist to pharmacy admin	1. PHARMACIST calls `/pharmacy-admin/overview`.	403.	No one
RBAC-007	Hospital admin to other hospital	1. Use an id from another hospital on approvals, break-glass, audit.	404 or 403; never data.	No one
RBAC-008	IDOR citizen	1. As Anjali change document, complaint, thread, session ids to ones from another citizen.	403/404; no data.	No one
RBAC-009	Header tampering	1. Send both `Bearer demo:CITIZEN` and `X-Demo-Role: CENTRAL_ADMIN`.	Bearer wins (citizen). Known: with only the header, any role is accepted in demo mode.	No one
RBAC-010	Web route guard	1. For each role load each other role's top URL.	Access-denied everywhere except its own.	No one
RBAC-011	Doctor outside a session	1. Doctor calls patient files for a patient with no session.	Empty/403; RLS blocks.	No one
RBAC-012	Gov cannot see patient data	1. Gov admins call patient-level endpoints.	403; reports are de-identified only.	No one

SAFE: safety invariants (any failure is S1)

ID	Scenario	Steps	Expected result	Who is notified
SAFE-001	Banner everywhere	1. Open every page of every role (use `/screens`) including login, 404, access-denied, splash, standalone screens, printed views.	"SYNTHETIC DEMO DATA" banner visible on each.	No one
SAFE-002	No raw Aadhaar	1. Search every screen and every API response in the Network tab for 12-digit numbers. Register with a 12-digit Aadhaar.	Only tokens (`tok_DEMO_...`, `DEMO-AADHAAR-...`) appear; the typed number is never echoed or stored.	No one
SAFE-003	AI always simulated	1. Check every AI output (doctor tools, citizen chat, summaries, gov AI governance).	Labelled simulated; no accuracy claims; guidance only; no autonomous diagnosis.	No one
SAFE-004	Doctor review first	1. Doctor runs AI; citizen checks before review, after accept, after reject.	Hidden, visible, hidden.	No one
SAFE-005	Patient events not to government	1. See NOTIF-008.	None.	No one
SAFE-006	Own record	1. See ACCT-007.	Refused.	No one
SAFE-007	Emergency alert permanence	1. Citizen tries to turn off Emergency in preferences.	400.	No one

ID	Scenario	Steps	Expected result	Who is notified
SAFE-008	No official look-alikes	1. Review login and landing pages.	No real government logos, no look-alike official pages.	No one
SAFE-009	Audit tamper-proof	1. Look for any way to edit or delete audit rows, events, documents, vitals, released results, signed prescriptions, MAR, handovers.	None in UI or API.	No one
SAFE-010	De-identified reports	1. Export a report as a gov admin; read the CSV.	No names or IDs of patients.	No one

SEC and NFR: security and non-functional checks

ID	Scenario	Steps	Expected result	Who is notified
SEC-001	API headers	1. Read response headers of any `/api/v1/*` call.	`X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: no-referrer`, `Cache-Control: no-store`, `Content-Security-Policy: default-src 'none'; frame-ancestors 'none'`.	No one
SEC-002	Web headers	1. Read headers of `/`.	CSP, `X-Frame-Options: DENY`, nosniff, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy: camera=(), microphone=(), geolocation=(self), payment=()`. Record that `access-control-allow-origin: *` appears on static pages (platform default).	No one
SEC-003	CORS	1. From another origin, call the API with credentials.	Blocked (same-origin only on Vercel).	No one
SEC-004	Clickjacking	1. Embed the site in an iframe.	Refused.	No one
SEC-005	XSS	1. Put `"><img src=x onerror=alert(1)>` in every free-text field (messages, complaints, reviews, notes, names, search).	Always escaped; no alert; stored safely.	No one
SEC-006	SQL injection	1. Put `' OR 1=1 --` in search boxes and IDs.	No change in results; 400/404.	No one
SEC-007	Upload attacks	1. Upload .html/.svg with script, renamed executables, huge files, 0 bytes.	Rejected by type, magic bytes or size.	No one
SEC-008	Rate limit	1. See AUTH-004. 2. Hammer other endpoints (e.g. 200 requests/min).	Access gate limits; other endpoints have no limit (record this).	No one
SEC-009	Double actions	1. Double-click sign Rx, dispense, approve, send alert; two admins approve the same request.	One result; the second gets 409 or an idempotent reply; no duplicate stock movement.	One set of events only
SEC-010	Concurrency	1. Two doctors open the same patient; two pharmacists dispense the same item.	Single doctor session; stock never negative.	No one
SEC-011	Large payloads	1. Send a 5 MB JSON body.	Rejected cleanly.	No one
SEC-012	Cookies	1. Inspect `cf_access`.	HttpOnly, Secure, SameSite=Lax, Max-Age 43200.	No one

ID	Scenario	Steps	Expected result	Who is notified
NFR-001	Clock	1. Compare `GET /api/v1/clock` with times in the UI after 10 minutes.	API frozen at 2026-10-17T09:15Z (14:45 IST); web clock drifts ahead. Record the visible effect (slot times, "waiting" tones, deadlines).	No one
NFR-002	Time zone	1. Check times on every page.	IST, 24h or 12h consistent.	No one
NFR-003	Performance	1. Time first load and 10 actions (cold start after 10 minutes idle).	Record seconds (earlier 2 to 5 s).	No one
NFR-004	Responsive	1. Test widths 360, 768, 1280, 1920.	No overlap, no horizontal scroll, banner visible.	No one
NFR-005	Browsers	1. Chrome, Firefox, Edge, Safari (iOS too).	Same behaviour.	No one
NFR-006	Accessibility	1. Keyboard-only path through registration and booking; labels; focus; contrast; screen-reader names.	Operable, visible focus, labelled controls.	No one
NFR-007	Refresh and Back	1. Refresh mid-flow on every multi-step form; Back/Forward.	State kept or cleanly reset; no double submit.	No one
NFR-008	Offline and errors	1. Go offline; trigger a server error (invalid id).	Friendly message; no stack trace.	No one
NFR-009	Tab session	1. Open the same role in two tabs; log out in one.	Other tab fails cleanly on next call.	No one
SEC-013	CSV formula safety	1. As Pharmacist create a dispensing override reason starting with `=1+1`. 2. Export the dispensing log CSV and open it in a spreadsheet. 3. Export a gov report CSV.	The cell shows `'=1+1` as text and nothing is calculated. Numbers (including negative) stay numbers.	No one
NFR-010	Print / export	1. Print a prescription, patient summary; export a dispensing log and a report.	Readable output; banner included; CSV only (PDF export gives 400 "PDF export is not available in the alpha. Use CSV.").	No one

KNOWN-ISSUES: confirm each one and record expected vs actual

#	Item	What to check	Expected	Actual (fill in)
1	No real login for any role	Passwords, OTP, MFA, lockout, reset, staff activation	Not built	
2	New accounts cannot sign in	After any registration try to log in as that person	Cannot	
3	Stale docs	Compare docs 15 and 16 to the app	App is ahead of docs	
4	Two-person rule paths	Legacy `/admin/approvals` vs `/gov/approvals`	Gov enforces; legacy does not	
5	Legacy inbox area scope	District admin sees all open requests of their level	Gov path scopes by area	
6	Clock drift	Web clock vs frozen API clock	Drift visible	
7	Old event links	Click every toast/bell item	No dead links	
8	`record_opened` invisible	See NOTIF-014	Patient should see it; may not	

#	Item	What to check	Expected	Actual (fill in)
9	No NOTTO / e-RaktKosh	Organ KNOS status, blood bank sources	Seed data only	
10	No email / SMS / Mailpit	Anywhere	Display text only	
11	Access-gate limiter only	Other endpoints have no rate limit	Only gate	
12	Upload size on Vercel	3, 5, 19, 21 MB	Fails near 4.5 MB	
13	Seed dates	Everything dated 17 Oct 2026	Frozen clock hides this	
14	AI verdict `edited`	Edit review saves	Works	
15	Doctor approval routing	Self-registered doctor goes to district, not hospital admin	Confirm intended	
16	Emergency window	15 minutes (doctor) vs 60 (citizen text)	Conflict	
17	Rotating key used-list	Per server instance	Reuse may pass	
18	Access gate fails open	If API is unreachable the gate shows nothing	Fails open	
19	`/screens/*` open	Reachable signed-out	Confirm intended	
20	Reviews without a visit	Allowed at any time (decision log)	Confirm	
21	Profile change approval	Approved change does not yet update the hospital row	Known gap	
22	Virus scan	Document `virus_status` stays pending	No scanner	
23	Static host CORS	`access-control-allow-origin: *` on pages	Platform default	
24	`comingSoon` strings	Look for "Coming in W2-W8" text in any menu	Should not show	
25	Missing roles	Block-level admin, front desk, ASHA, card-OTP access	Not built	

Open questions for the owner

1. What access code do testers use, and does it change?
2. Should newly registered accounts be able to log in at this stage?
3. Should a citizen see "record opened" alerts in the app?
4. Should a doctor's approval go to the hospital admin as well as the district admin?
5. Is `/screens/*` meant to be open without sign-in?
6. May testers turn platform flags (`bg`, AI, maintenance) on and off, and when?
7. Should ratings require a completed visit?
8. Is there a second central admin account for two-person tests?